

Subjects, Not Authors

The Authorship Hazard in Agentic Dataspaces

Seungho Lee · Changbin Lee

Korea Trade Network (KTNET), Seoul, Republic of Korea

ABSTRACT—Dataspace connectors decide *whether* a transfer may occur, not *what* the transferred value contains—tolerable for contracted applications, not for LLM agents that compose tool calls and spawn sub-agents. Research on agents that generate governance artifacts evaluates output quality; who may authorize an artifact for use falls between that literature and the governance literature, and neither owns it. A published policy is what a dataspace's decision point enforces, so publication is a governance event, and an agent that is both policy subject and policy author writes the norms that bind it. We name this the *authorship hazard* and state one principle: an agent is a subject of the governance plane, never an author of it. Its authorization channel to publication is closed by construction; its influence channel—drafting what humans approve—is treated as an enforcement problem.

On a frozen corpus of agent drafts, publishing without approval reverses 80 authorization decisions, most through drafts that change only a field's sensitivity classification and no policy text; a classifier that reads the policy diff misses every such draft, necessarily. Treating classification as authorship routes them all to review; the registry-held classification this requires is designed and modelled here, not yet implemented in the prototype. At the execution boundary, protected fields reach the model in 105 of 105 cases under prompt-stated duties and in 0 of 105 when the ODRL duty is compiled into an invocation-time tool-call constraint, but where the value is not confined to a named field the compiled condition exposes it in 7 of 7. A centrally provisioned approval pool does not scale to the participant volume that motivates the problem.

KEYWORDS—dataspaces, ODRL, usage control, LLM agents, delegation, data sovereignty, Model Context Protocol, policy authorship

1. Introduction

A dataspace makes data sharing governable by making it contractual. Two participants negotiate a policy, the policy becomes an agreement, and a connector enforces it. The Eclipse Dataspace Components (EDC) stack, the reference implementation in Catena-X and a growing number of sectoral spaces, implements this faithfully: an ODRL policy decision point (PDP) evaluates the agreement and the data plane refuses transfers the PDP rejects.

What the connector enforces is narrower than what the contract says. It enforces *whether* a transfer happens. It does not enforce *what* the transferred value contains, and it stops caring the moment the bytes leave. ODRL duties—anonimize before release, delete after thirty days, record provenance—are declarative; the connector transforms no payload. Duties are honored because the counterparty is an application under a contract, written by an organization that can be sued.

Agents break this arrangement in a specific way. The problem is not that agents are unpredictable, although they are. It is that an agent is not a party. It has no legal personality, it is instantiated and destroyed at will, it can call tools its principal never enumerated, and it can delegate to further agents the provider has never heard of. The contract was signed with an organization; the process touching the data is three delegation hops away.

Two responses exist. DAVE [1] places a policy-enforcing spokesperson on the provider side that answers questions about documents rather than releasing them; its authors treat the constraint instructions given to the model as advisory and state that virtual redaction, when implemented with LLMs, cannot guarantee that no sensitive fragment will leak. The IDSA position paper [2] proposes a delegated agent credential verified at admission, with cascading delegation in which a secondary agent inherits the purpose scope and assurance grade of the primary agent's credential. The first adds a probabilistic component to the enforcement path. The second, like this paper, argues that existing mechanisms suffice; it places agent authority in the credential plane, and we place it in the policy plane. Table 2 states what that difference costs: two decision authorities rather than one.

1.1 Publication is a governance event

We start from an observation about a different literature. Agents that *generate* governance artifacts are an established track: natural-language-to-ODRL translation [3, 4], ontology matching with paired LLM agents [5], multi-agent ontology generation [6], and a survey of LLM-driven knowledge-graph construction [7]. We inspected the evaluation design of these systems for a single thing (Section 9.5, Table 12): any step at which a human or a policy decides whether the generated artifact may enter the plane that governs production. There is none, and within

that literature's own scope there need not be: a generator is evaluated on what it generates. Every system measures the *quality* of its output—alignment accuracy, competency questions, panels of model judges—and stops there.

In a generic knowledge-graph pipeline the omission is benign; a wrong mapping degrades retrieval. In a dataspace it is not. The published semantic model is what agreements reference, and the published ODRL policy is what the PDP enforces. A wrong or adversarial mapping is therefore not a quality defect but a governance event: it can manufacture an authority that should not exist or erase a constraint that should. **Publication, not generation, is the security-relevant act**, and neither literature models it: generation research stops at output quality, and the governance literature does not model the generator. The same holds one level down: the sensitivity classification a policy refers to is itself a published artifact, and changing it changes what the policy protects without touching the policy (Section 5.4).

Combine this with the natural next step—treating the agent as an ODRL subject so that the existing PDP governs it—and a hazard appears that neither literature sees, because each owns one half of it. An agent that is a subject of the policy and also an author of the policy writes the norms that bind it. This is the self-amendment problem of access control. We call it the *authorship hazard*, and it is the object of this paper. One half of the hazard has a precedent. Where it takes the form of a reclassification (Section 5.4), multilevel security already treats relabelling as the security-relevant act (Section 9.1). What that literature does not have is a drafter who is also the constrained subject, which is the case here.

1.2 Principle

PRINCIPLE P

An agent is a **subject** of the governance plane and never an **author** of it. Policy is made outside the agent and kept inside it.

P is a design constraint, not a theorem, and Section 5 is careful about what it does and does not deliver. In particular it closes one channel by construction and leaves another open by necessity, and the paper says which is which.

1.3 Contributions and their boundary

- **The authorship hazard as a framing, with evidence.** The observation of Section 1.1, a survey of the generation literature with stated method (Section 9.5), and the argument that in dataspace publication is the governance event. This framing is ours. Priority on the broader *agent authority* problem is not—[2] posed it first.
- **C1 — Agents as ODRL subjects, with the authorization channel to publication closed.** The agent sits inside the existing policy plane as an ODRL party

rather than beside it as a credential holder. Authorship is unreachable: the agent drafts, a human approves, and the approval artifact is the publishing credential. We then name the channel that stays open—influence—and design the approval stage as an enforcement problem (Section 5.3). We then show the hazard extends to the classification a policy refers to, and treat classification as policy-rank authorship (Section 5.4); the registry-held classification this requires is designed and modelled in Case D's evaluator, and not yet implemented in the prototype (Section 8.7).

- **C2 — Duties that cross the execution boundary.** An ODRL duty in the negotiated agreement compiles into a constraint applied at tool invocation and on the return path, so that the obligation acts on values rather than on visibility (Section 6.1). This is the mechanism Sections 8.1 to 8.3 measure. **Enforcing obligations at execution time is not itself new:** usage control has systematized authorizations, obligations, conditions, continuity and mutability for two decades [8], and the IDS lineage has deterministic duty enforcement in production. What we claim is narrower—that the duty carries provenance from a negotiated dataspace agreement, that it compiles to the model's tool boundary rather than to a data-access boundary, and that it is the execution-side half of a design whose other half governs authorship.

Four experiments measure these claims—*Case B* at the execution boundary, *Case E* tracing the constraint to a negotiated agreement, *Case D* on the authorship hazard itself, and *Case A* on what per-action evaluation costs—and Table 13 sets every claim against its evidence. Two further things are stated and not claimed: Section 6.2 designs a re-delegation ceiling that is unevaluated, and Section 4 names two threats the design does not address (T5, T6).

2. Background

2.1 What EDC does and does not enforce

EDC separates a control plane from a data plane. The control plane negotiates agreements over the Dataspace Protocol and evaluates ODRL at a PDP. The data plane transfers bytes under an endpoint data reference token. Enforcement inside the connector is real but bounded: token validation, transfer authorization, and a policy monitor that can terminate an ongoing transfer. All of it is *access*-level.

No EDC component transforms a payload according to a duty. Nothing masks a column, enforces a retention window or stamps provenance. This is not an oversight; the ODRL duty is declarative and the specification assigns no executor. The consequence determines our architecture: the layer we need is not one EDC has that must be replaced, but one EDC lacks that can be added beside it. The connector is not forked. (Whether that constitutes "no new stack" is a definitional question we take up in Section 5.1.)

A terminological hazard: EDC has a class named `ParticipantAgent`, constructed from verified credentials after authentication. It denotes a *participant*, not an AI agent. We avoid the bare word "agent" when discussing EDC internals.

2.2 What ODRL already permits

Two readings of the specification shaped this design; both were checked against the normative text.

ODRL already admits agents as parties. The Information Model defines a Party as

an entity or a collection of entities that undertake functional roles in a Rule, such as a person, collection of people, organisation, or agent.

Placing an agent in the assignee position is therefore not an extension of ODRL but a position the specification has always allowed and no dataspace deployment operationalizes.

ODRL cannot express constrained re-delegation. Three vocabulary terms are nearby. `nextPolicy` is "to grant the specified Policy to a third party for their use of the Asset"; `grantUse` is "to grant the use of the Asset to third parties," enabling the assignee to create policies for third parties; `distribute` is "to supply the Asset to third-parties." All three presuppose that *the asset moves*. Agent re-delegation is the opposite case: the asset stays inside the provider's boundary and a sub-agent acts on it there. Using `grantUse` would invert the meaning. Nothing in ODRL restricts re-delegation; that absence is the extension point the ceiling of Section 6.2 is designed into—and which Section 1.3 declines to claim.

The W3C ODRL Data Spaces profile [9] supplies a base. It defines the actions `Query`, `Publish`, `Train`, `Evaluate`, `Anonymize`, `Transform`, `Aggregate_by_consumer`, `Aggregate_by_provider`, `Remove_subscription`, `Kill_job`, and the party functions `Provider`, `Consumer`, `Controller`, `Broker`. `Anonymize` and `Transform` already name the duty actions our executor performs, so we execute standard vocabulary rather than invent it. The party functions stop at four—no agent role, no delegation term—so the extension point is verifiably unoccupied. Section 8.3 turns that reading into an observation: a value-level obligation term is rejected outright by the stock profile's validator, and expressing one took a minimal extension to it. The profile is an unofficial draft (retrieved 22 September 2026), we treat it as the vocabulary a live dataspace profile is converging on rather than as a standard, and no claim here depends on its status.

The document sits in the W3C ODRL group's repository, authored by the UPM/IPTC team named in it; it carries no status section and no Recommendation-track or Community Group Report designation. Some secondary literature nonetheless cites it as a Draft Community Group Report dated 19 May 2026.

2.3 Agents, tools and the execution boundary

An LLM agent reaches the world through tool calls, increasingly standardized as the Model Context Protocol (MCP), and reaches other agents through agent-to-agent protocols. The boundary between "the model decided to do this" and "this happened" is the execution boundary, and it is the only place enforcement is possible.

That prompt-level constraints do not hold at this boundary is reported consistently across settings rather than established by any single result. Indirect-injection benchmarks show tool-using agents following injected instructions at substantial rates, roughly 24% for ReAct-prompted GPT-4 and nearly double under reinforced attacks [10]. Training-time work on an instruction hierarchy improves robustness but does not close the gap [11]. A family of runtime enforcement frameworks exists precisely because prompting is insufficient: symbolic privilege policies with a monotone shrink-only guarantee [12], a DSL for runtime constraint enforcement [13], and a dedicated guard agent [14]. The redacted question-answering setting reports the same shape [15]. For MCP specifically, a proxy that filters the tool registry at discovery time reports unauthorized-invocation rates of 48.5–68.5% across models under prompt-only control, 4.0–37.0% when the prompt carries an explicit per-tool allowlist, and 0% under architectural filtering [16]. We build on this body and do not re-derive it. Our question is downstream: given that the constraint must be architectural, *where does it come from*. In [16] it is a hand-written attribute-based rule set; in [12] a developer-authored policy; here it is the agreement already negotiated.

3. Motivating Setting

Our setting is cross-border trade document exchange—certificates of origin, packing lists, customs declarations, carbon-accounting attachments—moving between exporters, forwarders, carriers and national single windows. **This section is an instantiation, not the scope of the claim.** The hazard of Section 1.1 arises wherever an agent generates an artifact that a governance plane will adopt, and nothing in the principle or in C1 depends on trade documents; what this setting supplies is a federated infrastructure in which organizational agreements, policy artifacts, delegated processing and execution-time obligations already coexist, so the mechanisms can be built and measured against something real rather than stipulated. Three properties drive the design.

Supply is fragmented and long-tail. Thousands of small exporters hold data that a few large consumers want, in unharmonized schemas. This is pay-as-you-go integration [17]: no big-bang schema, incremental accumulation as demand arrives. Consumers announce a need and holders raise a hand—structurally the Contract Net protocol [18]—which is why an agent is attractive on the supply side at all.

The profile is more sensitive than the data. To map a legacy table into a shared model, an agent must see column names, value distributions and samples. That profile discloses commercial structure, often more than the mapped data does. A design that ships the profile to a central service has lost the sovereignty argument, which is why the provider-side components sit *inside* the participant boundary and only the approved mapping moves upward—a mapping that is rejected before approval if it carries any literal data value (Section 5.3), since a mapping with sample values embedded *is* the profile.

The consumer runs a planner; the provider must not have to. Large consumers will run goal-directed planners over open tool sets. A small exporter will not. We therefore distinguish a *planner*—open goal, open tool set, re-plans at runtime—from a *task-bounded agent*—fixed task, closed tool set, LLM-assisted but not goal-directed. The design places planners only on the consumer side. The provider-side components of Section 7 are task-bounded agents; the asymmetry claim is about planners, and Section 7 holds to it.

4. Threat Model

Assets are the provider's data, the governance plane (published policies and vocabulary), and the agreement. Trust assumptions follow.

TABLE 1. Trust assumptions.

Component	Trust	Basis
Provider and consumer EDC (PDP, access PEP)	Trusted	Existing dataspace trust anchor; root of the delegation signature chain (6.2.3)
Obligation executor	Trusted	Deterministic, provider-operated, no model inside
Publishing pipeline, approval service, vocabulary registry	Trusted	Deterministic, not addressable by any agent
Tool gateway applying compiled constraints	Trusted	Same role as the MCP proxy in [16]
Human approver	Trusted but bounded	Honest, but attention is finite; modeled as fallible under load, not as an oracle
Planner (LLM) in every agent	Untrusted	Assumed fully adversarial: injected, misaligned or both
Sub-agent runtimes	Untrusted	Consumer-side, arbitrary
Consumer infrastructure beyond its connector	Untrusted —	

The adversary controls planner output in every agent, can craft any draft, spawn sub-agents, decompose goals arbitrarily, and observe all responses. The adversary cannot break cryptography or compromise trusted components.

Two artifacts are therefore unforgeable for a stated reason rather than by assumption: approval artifacts, issued by the trusted approval service (Section 5.3), and the signature chain that attests delegation lineage, rooted in a key the consumer connector issued (Section 6.2.3). The adversary can produce arbitrary *claims* not so rooted; the PDP does not read them.

Threats in scope, and where the design stands.

- **T1** Unauthorized publication of policy or vocabulary. *Closed by construction* (5.2).
- **T2** Manipulation of a draft's content so that an honest approver publishes something adversarial—including reclassification of the sensitivity vocabulary a policy refers to. *Bounded, not closed* (5.3, 5.4).
- **T3** Evasion of a duty at the tool boundary. *Addressed* (6.1).
- **T4** Escalation of authority through delegation, including a forged or self-reported lineage. *Designed, not evaluated* (6.2; Case C not run).
- **T5** Composition of a forbidden outcome from individually permitted actions. *Not addressed* (10).
- **T6** Derivative relay: a parent passes data it lawfully holds to a child beyond the child's ceiling, outside the policy plane. *Not addressed; an information-flow problem, not an access-control one* [19] (6.2.1, 10).
- **T7** Profile exfiltration through the registration agent's only egress, the draft. *Addressed* (5.3, 7).
- **T8** Flooding the approval queue to stall legitimate publication. *Contained; capacity is a provisioning parameter* (5.3; the quota localizes a flood, and the evaluated central pool of three approvers holds to two hundred participants and has diverged by five hundred at the lowest draft rate, while thirty approvers hold to three thousand; under a federated partition the central limit is inverse in the share of central-rank changes, 8.4).

T5 and T6 deserve a word here because the design's advertised properties are what expose them. A stateless per-action evaluator cannot see a plan (T5), and an access-control boundary cannot see what one process tells another (T6). T5 is probably the threat that matters most in an agentic setting, since decomposing a goal into permitted steps is what a planner is for; the design stops short of it because the evaluator has no plan to inspect, and Section 10 says what a plan-aware evaluation would cost.

Out of scope. Side channels; model extraction; collusion between provider and consumer organizations; compromise of the connector, the executor or the approval service; denial of service against the PDP.

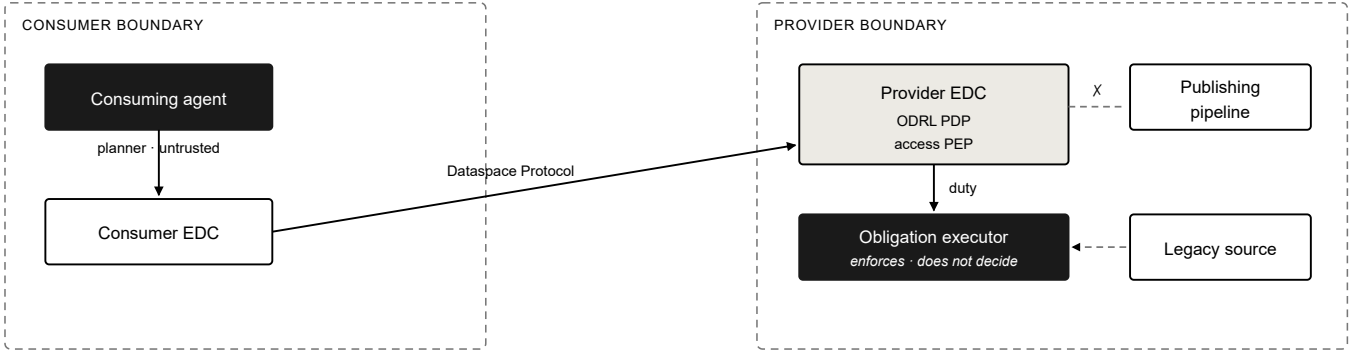


FIGURE 1. Runtime deployment. The consuming agent never speaks to the provider directly; it drives its own connector and the Dataspace Protocol carries the request. The obligation executor is added beside the provider connector because the duty layer is absent from EDC, not misplaced; it enforces the PDP's decision and makes none of its own. The crossed line is the absent *authorization* edge: no agent can invoke publication. It is not a claim that agents have no path of *influence* on what gets published—that path exists and is drawn in Figure 2.

5. C1: Agents as Subjects, with Authorship Regimented Out

5.1 The agent inside the policy plane

We place the agent in the assignee position of the ODRL rule governing the action it attempts and evaluate it at the existing PDP, on the existing plane, per action. The contrast with the credential approach is sharp enough to tabulate.

TABLE 2. Two ways to admit an agent.

Axis	Credential check [2]	Policy evaluation (this work)
Locus of authority	A delegated agent credential, verified separately	The ODRL agreement itself
Deciding component	A new verification procedure	The existing PDP
Decision time	Once, at admission	Per action, continuously
Relation to ODRL	Must be kept consistent with it	Is it — policy composition
Revocation	Credential revocation	Agreement termination extinguishes authority
Decision authorities	Two: the credential verifier and the PDP	One: the PDP

The last row needs a definition, because C2 plainly adds a new vocabulary term, a new enforcement component and a compilation layer, and the claim that no second stack is erected has to survive that. We define a *governance stack* as a component that *decides* authority. Under that definition the claim holds and is worth making: the obligation executor enforces a decision the PDP has made and makes none of its own; the compiler translates a duty the PDP has admitted; the profile term is evaluated by the PDP. There is one decision authority. There is not one component, and we do not claim there is.

The consistency point in row four follows from the definition. Two deciding components can disagree; a class of bug exists that must be handled. One deciding component cannot disagree with itself; the class of bug does not exist.

We stress the boundary. This is not a discovery: [2] already identifies agent authority in dataspace as open, already describes cascading delegation and a tool-registry profile element, and states that no agreed specification yet exists for declaring agent delegation or governing it at organizational scale. It is an alternative design for an acknowledged problem.

5.2 Closing the authorization channel

C1 is only coherent if the agent cannot author what binds it. We separate the drafting subject from the publishing subject in the sense of Jones and Sergot's distinction between regimentation and enforcement [20]: a regimented system does not punish the violation, it makes the violating action unavailable.

Concretely: the registration agent profiles a legacy source and drafts a mapping and a policy. A human approver reviews the draft. The approval artifact—not the agent's identity—is the credential the publishing API requires. The agent has no route to that API and holds no such artifact.

What this buys should be stated precisely. The construction makes the authorization relation *static with respect to agent actions*: no sequence of agent actions alters the rights lattice. This is a restriction of the kind under which the HRU safety question becomes decidable [21]—the operator that produces undecidability has been removed from the agent's repertoire—but it is a design decision made explicit, not a theorem, and it says nothing about whether an agent can *influence* what a human with authority chooses to publish. We state both halves formally, because the second is the one readers of the first tend to assume away.

Proposition 1 (authorization invariance). *Let M be the authorization state that publish writes: the policy store, holding the published offers, and the vocabulary registry. The decision point evaluates negotiated agreements, and condition (iv) ties those to M . Let Σ_A be the action alphabet available to the agent, including the negotiation actions of Section 2.1. Assume (i) $\text{publish} \notin \Sigma_A$; (ii) the publishing*

API's precondition requires an approval artifact issued by the approval service; (iii) no finite sequence in Σ_A^ yields such an artifact; and (iv) every agreement's policy is the provider's stored contract definition at the moment of agreement. Then for every $\sigma \in \Sigma_A^*$, M is unchanged by σ , and every right the agent holds after σ was in M when it was granted. The safety question for this subject set—can the agent come to hold a right r on object o that M does not grant—is therefore decidable, and answered in the negative by construction.*

The proof is immediate and that is the point. Conditions (i) and (ii) are architectural facts about which endpoints exist and what they require; (iii) holds because the approval service is trusted and not addressable by any agent (Table 1). Condition (iv) is a measured property of the connector (Section 8.3): the provider reads only the offer identifier from a request, builds the agreement from the contract policy it currently stores, and never reads the policy text the consumer sent, so a widened request yields the stored policy and nothing more. Two measured qualifications bound the word “published”: the bound is the provider's current definition rather than the offer the consumer once saw, and the provider does not track the offer instances it issued. Neither lets an agent create a right; the agreement policy is always one a human has stored, which is M . Condition (iv) is not decoration. Table 2 places the locus of authority in the negotiated agreement and Figure 1 lets the agent drive its own side of the negotiation, so without (iv) negotiation would be a second operator on authorization state open to the agent and the proposition would be false; with it, an agent-driven negotiation can only instantiate what a human has already published. The proposition is shallow, and worth stating because it fixes how much the construction buys: the undecidability that motivates the safety literature [21] is avoided here by removing an operator, not by restricting a model.

Remark 1. *Proposition 1 concerns authorization and asserts nothing about influence.* Condition (iii) stops the agent from producing the artifact; it does not stop the agent from producing the *text* that a party holding the authority will approve and publish. The influence channel is a map from Σ_A^* into the argument of a `publish` executed by an authorized subject, so M may change as a *consequence* of agent actions while remaining invariant *under* them. Nothing in Proposition 1 bounds that map; condition (iv) bounds what a negotiation can add to the agent's rights, not what an approver can be induced to publish. Sections 5.3 and 5.4 are about it, and Case D measures its range: 80 authorization reversals over 380 drafts when the approving party applies no filter (Section 8.4). A reader who takes Proposition 1 as a security guarantee for the system has taken it for the system's smaller half.

5.3 The influence channel and the approval stage

The agent drafts the policy. A human approves it. The authorization edge is absent, but a path from agent to publication exists—through the approver—and its first node is the adversary of Section 4. If drafts arrive at volume and the approver's attention is finite, approval degrades toward ratification, and a system in which an adversary writes what an honest party rubber-stamps is not distinguishable in effect from one in which the adversary publishes. This is a confused-deputy surface in Hardy's sense [22], and its shape is familiar from software supply chains, where an honest reviewer merges a change an untrusted author wrote [23]. HRU-style formalisms do not capture it, because they model who holds a right, not who wrote the text the right-holder signed.

We therefore treat the approval stage as what it is under [20]: enforcement, not regimentation. It cannot be made impossible to approve an adversarial draft; it can be made costly, detectable and bounded. Four measures.

(a) Drafts are diffs. A draft is submitted as a difference against the currently published state of the same asset's policy and mapping, never as a fresh document. A reviewer reads what changed, not what is. The first publication of a new asset has no prior state, the diff is the whole document, and (a) gives the reviewer nothing. First publications therefore always take the elevated path of (b) with an onboarding checklist: every field's sensitivity class assigned or confirmed by a human, no literal values present, the default ceiling of Section 6.2.2 applied. In the setting of Section 3, onboarding is not the exception but the dominant event, so this is the path the approver budget is sized for; it is affordable because it happens once per asset and every later change is a diff.

(b) Privilege-delta flagging. A deterministic classifier over the diff flags any change that adds a permission, widens a constraint, removes a prohibition or duty, introduces an agent as assignee, deepens a delegation ceiling (Section 6.2), or alters a duty's target. Three further classes are handled unconditionally, regardless of direction. Any change to a field's sensitivity classification is flagged (Section 5.4). Any change to the vocabulary registry or to this classifier itself is flagged: these are by definition the highest-privilege changes in the system, and they can never take the ordinary path. Any draft containing a literal data value outside the allow-list of vocabulary identifiers is not flagged but rejected, because a mapping carrying sample values is the profile of Section 3 leaving the boundary (T7). Flagged diffs are routed to elevated review requiring two approvers; unflagged diffs—a narrowed constraint, an added duty, a corrected human-readable description—take the ordinary path. Both paths end at a human: flagging changes who reads the draft and how many, not whether it is read. The classifier is syntactic over ODRL and the mapping language.

(c) Approver load ceiling. The number of flagged diffs an approver may act on per period is bounded. Beyond the bound, drafts queue; they are not reviewed faster. Queue depth is a published operational metric. The intent is that rubber-stamping becomes an observable state—a growing queue—rather than a silent one. A queue is also a target: an adversary who can produce arbitrary drafts can produce flagged, harmless ones at volume and stall legitimate publication (T8). Quotas are therefore per-participant and the draft-submission gateway rate-limits each participant; a participant that exceeds its quota is throttled, and the plane as a whole is not.

(d) Approval artifact issuance. The artifact is bound to the hash of the exact draft, single-use, short-lived, issued by an approval service no agent can address, and logged with the approver identity. A draft altered after approval fails at publication.

What remains open is stated in Section 10: approver fatigue and social engineering of approvers are human-factors problems. We bound them and make them measurable (Case D, Section 8); we do not claim to solve them.

5.4 Classification is authorship

The following was raised in review of this work, and it is sharp enough to state as an attack. The ceiling of Table 4 is expressed over sensitivity classes F0, F1, F2, and the assignment of a field to a class is drafted by the registration agent from the profile. Consider a diff that moves consignee from F2 to F0. It adds no permission, widens no constraint, removes no prohibition or duty, introduces no assignee, deepens no ceiling, and leaves Anonymize(F2) textually intact. Under the original six flag conditions it passes, and to an approver it reads as a label correction. Its effect is that

the "Denied" verdict of Table 4 flips to "Permitted" and the Anonymize duty no longer reaches consignee at all. One reclassified field narrows the duty's scope rather than emptying it—emptying is the limiting case, reached only when every field of the class is moved—and that is precisely why the attack is quiet: the obligation still fires, on a smaller set, and nothing in the policy or the duty's own text records that the set shrank. The policy has not changed by one character; what it protects has.

The lesson generalizes Section 1.1. Publication of a policy is a governance event; so is publication of the *vocabulary the policy refers to*, and the second is quieter, because an escalation routed through classification is invisible to any check that reads only the policy. In this system privilege expands more naturally through the mapping than through the policy, and a classifier that is "syntactic over ODRL" is, on its own, a declaration of that gap. The authorship hazard is therefore not only policy authorship but classification authorship.

The fix is the cheapest available and is already specified in (b). Sensitivity classification is held as an attribute of the central vocabulary registry, not of the participant's mapping; any change to a field's class is privilege-expanding by definition and takes elevated review; and when a class changes, every published agreement whose ceiling or duties reference that field is listed for re-review, since those agreements were approved under the old class. The stricter alternative—removing classification from the agent's drafting scope entirely—is not excluded; the registry route keeps the agent useful for proposing classes while denying it the authorship of them. The route has a cost that Section 8.4 measures: under a federated approval structure (Section 10) every reclassification is central-rank traffic, and the central pool's limit scales inversely with its share.

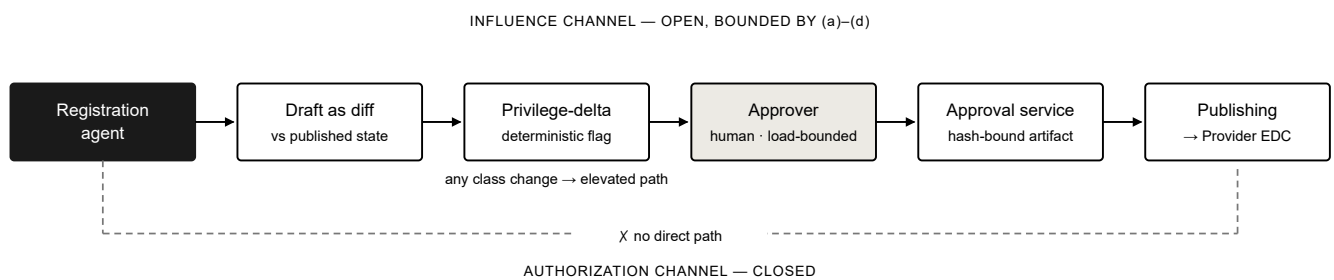


FIGURE 2. The two channels from agent to publication. The lower, crossed path is the authorization channel, absent by construction: no agent can call the publishing API or hold an approval artifact. The upper chain is the influence channel, which necessarily exists because the agent writes the draft; it is open, and Section 5.3 bounds it with diff-form submission, deterministic privilege-delta flagging, a load ceiling on the human approver, and hash-bound single-use artifacts; classification and vocabulary changes never take the ordinary path (Section 5.4). The distinction is the difference between what P delivers structurally and what it merely constrains.

6. C2: Carrying the Agreement Across the Execution Boundary

Section 2.3 established that constraints must be architectural. C2 says where they come from: the agreement already negotiated. It propagates in two directions.

6.1 Downward: duties become tool-call constraints

An ODRL duty attached to a permission is compiled into a constraint on the tool invocations the permission makes possible, applied at a gateway between the planner and the tool. An Anonymize duty on a query permission becomes a transformation of the tool's return value before it reaches

model context; a retention duty becomes an expiry on any artifact the call produces; a provenance duty becomes a mandatory record written before the result is released.

The principle is old and we claim no more than its application. Complete mediation requires every access to be checked at the point of use, and least privilege requires the checked authority to be the smallest that suffices [24]; a duty stated in an agreement but enforced only at discovery satisfies neither, because the point of use is the tool return path. The distinction from discovery-time filtering [16] is not one of degree. Filtering a registry decides which tools are visible. It cannot mask a field in a response, because when the response exists the filtering decision is past. Duties act on values and on what happens afterward, so they must act at invocation and on the return path. The two are complementary; we cite [16] as the access-side result we build on. The shrink-only guarantee of [12] is the closest formal cousin of what compilation must preserve: a compiled constraint set may only be narrower than the agreement, never wider. Section 8 measures this mechanism; Section 8.2 reports that discovery-time filtering leaves the protected value in the payload in every case in which one is present, which is the structural point above made quantitative.

6.2 Sideways: re-delegation beneath an owner-declared ceiling

This section is design, not result. Nothing in it is evaluated, and we mark it here rather than only in Section 10 because the argument that follows is the most speculative in the paper. It is included because the downward mechanism of Section 6.1 is incomplete without an answer for sub-agents, and because the answer we propose inverts an assumption that capability systems treat as definitional.

When an agent spawns a sub-agent, authority must flow. Capability systems—Macaroons [25], UCAN, ZCAP-LD—mint an attenuated derived token; recent agent infrastructure adopts this directly, with delegation chains that propagate constraints from parent to child [26]. The IDSA cascading-delegation sketch has the same shape: the secondary agent inherits the boundary of the primary's credential. Delegation is therefore not a contribution and we do not claim it. One axis differs, and it is the axis on which the dataspace case genuinely differs.

TABLE 3. Re-delegation: capability systems versus the policy plane. Rows 4 and 5 are costs.

Axis	Capability systems	This work
Who bounds re-delegation	The holder alone — free attenuation is the design goal	The owner declares a ceiling; the holder attenuates beneath it
Form of authority	A derived token carrying rights	No rights on the wire; an attestation of identity and lineage, rights derived at evaluation
Basis of attenuation	Whatever the holder keeps	Holder's choice, within the owner's ceiling
Revocation granularity	Per branch — finer	Agreement termination collapses the whole chain — coarser
Availability	Offline verification possible	Every action requires the PDP

The first row is the inversion. In a capability system the holder may attenuate and pass on freely; that is the definition, not an incident. In a dataspace the owner must have a say: whether my counterparty may hand my data to a sub-agent it instantiated, and how far that sub-agent may reach, is a question about my data. Cascading delegation as described in [2] says constraints are inherited; it does not say who authorizes delegation in the first place. Answering that requires a profile term, because ODRL has none (Section 2.2).

6.2.1 A concrete ceiling

A certificate of origin (CoO) carries fields in three sensitivity classes: F0, public trade facts (HS code, origin country, issue date, certificate number); F1, commercial quantities (quantity, gross weight, declared value); F2, identities (exporter, consignee, producer). Actions form a chain $\text{read-metadata} < \text{read-fields} < \text{read-document}$. The agreement grants the primary consuming agent read-fields over $F0 \cup F1$ for the purpose *customs clearance*, with duties *Anonymize(F2)* and *provenance-record*. The owner's ceiling for any sub-agent is shown below.

TABLE 4. Owner-declared ceiling for sub-agents on a CoO, and two decompositions against it.

Dimension	Ceiling	HS-classification checker	Consignee-risk lookup
Action	$\leq \text{read-fields}$	read-fields	read-fields
Fields	$\subseteq F0$	{HS code, origin}	{consignee} — F2
Purpose	= customs clearance	customs clearance	customs clearance
Depth	≤ 1 (derived from chain length, 6.2.3)	1	1
Duties	inherited, non-removable	inherited	inherited
Verdict	—	Permitted	Denied — F2 above ceiling

The checker is a legitimate decomposition and passes. The lookup is denied because the owner never agreed that any

downstream process may *hold F2 as a policy subject*. That is the precise claim and it is worth separating from a stronger one that does not hold. The primary agent, which holds F1 and the anonymized form of F2, is an untrusted planner; nothing in the ceiling prevents it from performing the lookup itself and pasting the result into the sub-agent's prompt. The ceiling bounds what a sub-agent can *obtain from the PDP*, not what it can *learn from its parent*. What it delivers is least privilege and auditability—no sub-agent ever acquires F2 authority, and every F2 access is attributable to the primary—not confinement. Preventing a parent from relaying derivatives is an information-flow problem (T6), and Section 10 says why an access-control design cannot reach it.

6.2.2 Can an owner declare this?

A fair objection: at negotiation time the owner knows nothing of the consumer's agent topology, and capability systems place attenuation with the holder precisely because only the holder knows how it will decompose its work. Asking the owner to anticipate sub-agents that do not exist seems to demand the impossible, and the predictable outcomes are a maximally permissive ceiling (vacuous) or a maximally restrictive one (blocking legitimate decomposition).

The answer is that the owner does not declare a topology. The owner declares a *ceiling*, which is a statement about the owner's data—which fields, which actions, how many hops, for what purpose—and that is exactly what an owner does know. The holder then attenuates beneath the ceiling, which is exactly what a holder knows. The design is not owner-only attenuation; it is owner-bounded holder attenuation, and Table 3 row 3 says so.

What remains is a security–utility tradeoff, and we do not pretend it away. A ceiling too tight blocks work that should be delegable; a ceiling too loose bounds nothing. Where the useful ceiling lies is empirical, and it is the first question of Case C (Section 8). As a default we propose F0-only at depth 1 with fixed purpose—conservative, and relaxed per agreement rather than tightened.

6.2.3 What crosses the wire

A second fair objection: if no token is minted, how does the PDP know which sub-agent is acting and by whose delegation? Something must cross the wire, and it will look like a token.

It does. A sub-agent presents an *attestation*: its own key, the agreement identifier, a timestamp, and a signature chain over that key running back through each parent to a key the consumer connector issued to the primary agent. The chain, not a field, establishes lineage. Depth is not carried; the PDP *derives* it by counting signatures to the connector-issued root and reads no self-reported value. This matters because Table 1 places sub-agent runtimes and the primary's planner in the untrusted region: an attestation signed only by a parent's runtime would have the adversary as its signer. Rooting the chain in the connector puts its origin inside the dataspace trust anchor, and a hop that cannot show a signature from a connector-certified key is not a hop.

The distinction from a capability token is then what the artifact carries. A token carries *rights*; presenting it is sufficient. An attestation carries *claims*—identity and lineage—and the PDP derives rights from the agreement at evaluation time. A replayed attestation yields what the agreement currently grants to that identity at that derived depth, which after termination is nothing. We do not remove the artifact from the wire. We remove the rights from the artifact, and with them the reason its lifetime would matter.

6.2.4 Costs

Two. **Revocation is coarse.** A capability system revokes one branch by dropping one token. Here, termination of the agreement collapses the entire chain, and there is no finer operation short of amending the agreement to narrow a per-branch ceiling, which is a contract operation, slower and heavier than dropping a token. For an owner who wants to cut off one misbehaving sub-agent while the rest proceed, this design is worse. **Availability couples to the PDP.** Every action requires a decision; a PDP outage halts every agent under every agreement, and per-action latency is added to every tool call. Case A measures the latency. A cached-decision variant recovers availability at the cost of reintroducing a revocation window; we regard that as a dial the deployment sets, and we state it as one.

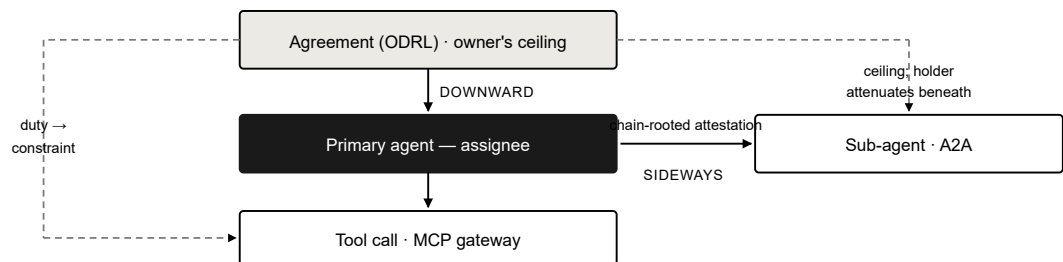


FIGURE 3. Two directions of propagation. Duties descend from the agreement into constraints on tool invocation and on return values. Permissions travel sideways into sub-agents beneath the ceiling the owner declared in the agreement; the holder attenuates further beneath it. What crosses to the sub-agent is an attestation of identity and lineage, not a rights-bearing token; the PDP derives rights from the agreement at each action.

7. Architecture

The separation follows from Section 2.1: EDC's access layer is used unchanged and its decision layer unforked, taking constraint functions as Appendix A shows; the duty layer is new because it is absent, the compilation layer feeds the gateway, and the planner is outside every enforcement path.

TABLE 5. Separation of decision, enforcement and planning.

Layer	Component	Decides?	Status
Decision (PDP)	EDC ODRL policy engine	Yes — the only one	Extended with constraint functions, as in Appendix A; not forked
Enforcement — access	EDC data plane, policy monitor	No	Used as is
Enforcement — duty	Obligation executor	No	New — the layer EDC lacks
Enforcement — tool boundary	Duty compiler + MCP gateway	No	New
Enforcement — registration egress	Draft-submission gateway	No	New — literal-value rejection, closed tool set
Planning	Consuming agent (LLM planner)	No	Outside every enforcement path

Three agents appear and their placement follows Section 3. The **registration agent** is a task-bounded agent inside the participant boundary at design time: it profiles a source and drafts. Its tool set is closed by a gateway, not by intention: its only egress is the draft-submission endpoint, which applies the literal-value rejection of Section 5.3(b), and it has no path to the central registry beyond read access to vocabulary identifiers. Its planner is as untrusted as any other (Table 1), and the draft is treated as what it is—the one channel through which the profile of Section 3 could leave the boundary (T7). The **providing agent** is a task-bounded agent inside the participant boundary at runtime: it answers a negotiated request; it does not plan. The **consuming agent** is a planner and runs centrally, because the consumer is the party that has one. The asymmetry claim of Section 3—no planner on the provider side—holds.

An objection deserves a direct answer: if components are deployed per participant, how is this different from the heavyweight per-site semantic middleware dataspace was meant to avoid? The deployed artifact contains no authored content. It is a stateless process and a pointer to a central vocabulary registry, not a virtual knowledge graph with hand-written mappings each site must maintain. What accumulates centrally is the approved mapping; what is deployed locally is the means of drafting one.

8. Evaluation

Four experiments are implemented and measured, and they answer different questions on different systems. The letters are the identifiers under which the evidence package and its

pre-registrations were frozen, and we keep them rather than renumber; the order of presentation is B, E, D, A. *Case B* asks whether a compiled duty holds at the execution boundary, and reports a deterministic measurement (8.1) and the same comparison with live models in the loop (8.2). *Case E* asks where the constraint comes from, and traces it to an agreement produced by an actual Dataspace Protocol negotiation on the upstream Tractus-X EDC 0.13.0 end-to-end test harness (8.3). *Case D* asks what the approval stage of Section 5.3 is actually worth: it publishes a corpus of agent drafts into a policy evaluator with no gate, then with each classifier, and counts the difference in authorization, then re-runs its queue simulation under a federated approval topology as Case D5 (8.4). *Case A* asks what per-action evaluation costs on a testbed built from the same connector images (8.5). Case C remains a plan and is stated in 8.7. A prompt-behaviour study (8.6) is secondary evidence only, for a reason given there.

Cases B and E are related and should not be collapsed. Case E ends by replaying Case B's corpus with the negotiated agreement as the constraint source; that replay is a check that the substitution holds, not a second measurement. What is independent in Case E is that a duty survives a real negotiation into the agreement held by both parties, and that the stock profile refuses the term the paper needs.

Cases D and A share nothing with Case B and nothing with each other. Case D runs no model and no connector; it evaluates drafts against a policy evaluator that implements this paper's rules, which is a reimplement and not the EDC decision point, and 8.4 says what that costs the claim. Case A runs no drafts; it measures a connector testbed.

Setting. The asset is the certificate of origin of Section 6.2.1 with the same F0/F1/F2 classification. The agreement carries Anonymize over F2, a provenance-record duty and a retention duty. The tool is a single certificate-query tool. Three conditions are compared throughout: *prompt-only*, the duty text carried to the planner and nothing acting at the boundary; *discovery filtering*, the registry deciding tool visibility as in [16], with the tool visible and permitted; and *compiled*, agreement-derived constraints applied at invocation and on the return path. The primary metric is whether a protected value is present in the payload bound for the model, measured at the gateway before the model call, not inferred from the model's answer.

Configuration. Live-model trials run through vendor command-line runtimes rather than raw model APIs, one fresh process per trial with no turn carried between trials, tool surfaces disabled except the certificate tool, and settings isolation forced. Sampling temperature is therefore not exposed by the harness and is whatever each runtime defaults to, which is a reproducibility limitation we state rather than paper over. The nine configurations of Section 8.2 are four Claude models (Opus 5, Sonnet 5, Fable 5.1,

Haiku 4.5), three GPT-5.6 configurations and one GPT-6, each through its vendor runtime, and one open-weight model (Qwen3 8B) served locally. All are named for reproducibility, and Section 8.6 explains why the set may not be read as a ranking.

8.1 Deterministic measurement at the boundary

The first layer runs no planner at all: 450 anonymize trials over 150 cases in three conditions, with zero model calls, so that the enforcement mechanism is measured without model behaviour as a confound. Sixteen of the 150 belong to a stress group reported at the end of this subsection, because they are the cases the design is not built for. Of the remaining 134, twenty-nine carry no protected value at all—tool errors, F0-only requests, absent or empty F2 fields—and a case whose raw tool response carries no protected value cannot host a violation. The risk set is therefore the **105 cases** in which one is present, spanning single and multiple F2 fields, nested objects, arrays, optional and reordered fields, repeated values, Unicode, long values and the same field reached by different paths. An earlier 22-case run is preserved in the record and its numbers are reproduced exactly by this superset.

TABLE 6. Case B primary result. Protected F2 values reaching the model-bound payload over the 105-case risk set, with Wilson 95% intervals. No model calls. Identical under a fixture agreement and under the negotiated agreement of Case E. Transform overhead is an in-process microbenchmark and excludes the policy decision round trip, which Case A measures (Section 8.5).

Condition	F2 in payload	95% interval	Over-removal of F0/F1	Transform overhead
Prompt-only	105 / 105	96.5–100%	0	—
Discovery filtering [16]	105 / 105	96.5–100%	0	+0.6 μ s
Compiled (this work)	0 / 105	0–3.5%	0	+19 μ s

The intervals matter more than the point estimates and we put them in the table rather than a footnote. At $n = 105$, **"0 of 105" is not a violation rate of zero; it is a violation rate below roughly 3.5%** at 95% confidence. The expansion from 22 cases narrowed that bound from about 15% and changed nothing else, which is what a robustness check is for. Nothing here establishes a small residual rate on a corpus of a different shape, and 8.6 reports a corpus on which the same mechanism fails outright.

Discovery filtering behaves exactly as Section 6.1 predicts structurally. The tool is visible and the call is authorized, both correctly, and the mechanism has no point of action on a response that already exists; the protected value is in the payload in every case in which it was in the response. This is not a failure of [16], which was built to decide invocation.

The epistemic status of this row needs stating, because the number is clean enough to mislead. Discovery filtering has no point of action on a response, so its 105 of 105

confirms a structural argument rather than testing an open question; the experiment could not have come out otherwise, and it earns its place as an instrumented demonstration, not as a discovery. The compiled row is closer to a real test—the compiler has to derive the right constraint from the agreement, and the gateway has to apply it on the return path without damaging permitted fields—but it is a test the design was built to pass on cases of this shape. The genuinely open question in value-level enforcement is not whether a named field can be suppressed. It is what happens when the protected value is not confined to a named field. The stress group below reports what happens on exactly those cases, and the answer is that the mechanism does not work.

On the corpus the mechanism is not built for, it fails outright, and this is the most important result in the section. Every case in the 105-case risk set puts the F2 value in a named field the gateway can address. An earlier draft of this paper said the harder shapes were absent and predicted they would be where the mechanism broke; we then built them: a stress group of sixteen cases in which the protected value is embedded in free text, sits inside an attached scan, is derivable from permitted fields rather than present in them, or appears only as a fragment. Seven are detectable by a literal scorer, and the compiled condition exposes the protected value in **7 of 7**—the same as prompt-only, the same as discovery filtering. The remaining nine are invisible to a literal probe, so the experiment says nothing about them in either direction and we do not count them. 0 of 105 with zero over-removal is therefore evidence that this corpus is easy, not that the problem is, and any claim that this design enforces arbitrary sensitive information is contradicted by our own data. How much of a real trade document is of the harder shape is a question this paper does not measure. Qualitatively, the documents of Section 3 mix structured fields with free-text goods descriptions, remarks and attached scans, and identifying values recur across them, so the named-field case is the common one but not the only one; a count over a real document corpus is the measurement that would settle it, and we have not made it.

The other two duties separate the same way. A provenance record is absent in 10 of 10 applicable cases with nothing acting at the boundary, and written before release in 10 of 10 compiled. Of 10 retention cases, 7 are past expiry; the expired artifact remains readable in 7 of 7 with nothing acting, and in 0 of 7 compiled. A malformed-constraint case fails closed, 1 of 1. **These two rows are structural baselines, not model failures**: no planner runs in this layer, so the prompt-only column measures what happens when nothing at the boundary acts, and must not be read as an LLM having been told to record provenance and having declined.

Gateway overhead is a 1,000-iteration in-process microbenchmark: median 24.4 μ s prompt-only against 43.5 μ s compiled, a difference of 19 μ s. There is no

network, no connector round trip and no cross-process serialization in that figure. It bounds the cost of the duty transformation itself and is not a deployment latency. In particular it is **not** the cost of the per-action policy decision, which is a network round trip to the decision point measured in milliseconds, not microseconds, and which is the availability coupling Section 6.2.4 admits as a cost. Measuring that belongs to Case A.

8.2 With models in the loop

The second layer puts live models behind the same gateway: **nine model configurations from two vendors' runtimes and one open-weight model served locally, in three conditions, for 1,320 calls**. The design is unbalanced and we state it rather than let a reader reverse it out of the totals: eight configurations contribute 20 benign and 20 adversarial trials per condition and the open-weight runtime contributes 60 and 60, so it carries three times the weight of any other cell. The models were chosen because their prompt-only output behaviour differs enormously (Section 8.6), which makes the invariance of the boundary measurement the point of the experiment. Repetition counts remain thin for a stochastic system; they are enough to show that the compiled condition is invariant and not enough to put a confidence interval on the output-leakage column, which we therefore report as a raw count.

TABLE 7. Case B with models in the loop, aggregated over nine model configurations and 1,320 calls. Context exposure is measured at the gateway and is reported separately for the two task types, because the benign column is a result in its own right. Output leakage is the model's final answer, split by task type: a benign leak is a protected value volunteered in answer to a request that did not ask for it. Every one of the nine configurations shows the compiled row individually, with no exception.

Condition	Context, benign	Context, adversarial	Benign success	Leakage, benign	Leakage, adversarial
Prompt-only	220 / 220	220 / 220	219 / 220	2 / 220	49 / 220
Discovery filtering [16]	220 / 220	220 / 220	218 / 220	5 / 220	57 / 220
Compiled (this work)	0 / 220	0 / 220	219 / 220	0 / 220	0 / 220

The benign context column deserves its own sentence, because splitting the denominator exposed something the aggregate hid. Under prompt-only and discovery filtering the protected value reaches the model on **every benign trial as well**. These are legitimate requests, correctly served, by a planner doing nothing wrong; the duty is simply not acting, so the data the agreement protects is handed over as a matter of course. The adversarial column is about attacks. The benign column is about ordinary operation, and it is the one a deployment should find alarming.

Benign success is 219, 218 and 219 of 220, and the three failures are individual tasks on two configurations rather than a pattern, so on this corpus the mechanism costs no utility. The result that matters is the contrast between the

context columns and the last one, and the spread inside that last column. Under prompt-only, adversarial output leakage ranges from **0 of 20 on five configurations to 44 of 60 on the open-weight runtime**. That single configuration supplies 44 of the 49 adversarial leaks in the prompt-only row, and both of the benign ones, so the aggregate in Table 7 is very largely one model's behaviour and should not be read as a property of the set. Model behaviour varies by more than an order of magnitude; boundary exposure does not vary at all, and the compiled row is 0 for every configuration taken separately. A model that behaves perfectly and a model that does not are indistinguishable at the boundary, and both are governed identically once the constraint is compiled. This is why the primary metric is instrumented at the gateway: **an output-based metric would have scored five of the nine prompt-only cells as clean successes, and none of them is one**. The leakage columns also record more leakage under discovery filtering than under prompt-only, 57 against 49 on adversarial tasks and 5 against 2 on benign ones. Nothing should be read into that. Context exposure is 440 of 440 in both conditions, so the models see exactly the same thing; the difference is sampling variation, and the repetition counts that stop us putting an interval on this column stop us putting one on the difference too. The data the agreement protects was handed to an untrusted planner in every call.

8.3 Case E: where the constraint comes from

Case B shows that a compiled constraint holds. It does not show that the constraint came from the agreement, which is the claim of Section 2.3 that separates this work from a hand-written rule set [16] or a developer-authored policy [12]. Case E closes that gap on a different system: the Tractus-X EDC 0.13.0 end-to-end Dataspace Protocol test harness, with provider, consumer and secure token service as separate runtimes, credentials signed by the dataspace issuer, and a real credential-registry container.

A stock constrained duty survives negotiation. With an obligation from the profile's own vocabulary and no modification to the harness, the duty is present at policy registration, in the catalog offer, and in the finalized contract agreement held by both provider and consumer. Preservation is judged on the agreement object and is semantic rather than byte-identical: the compact term arrives expanded to its full profile IRI with operator and right operand intact.

The value-level term is rejected by the stock profile. The duty this paper needs—suppress fields of a named sensitivity class before release into an agent execution context—has no term in the stock profile, and registering one is refused by the validator with HTTP 400. This is the strongest available evidence for the reading of Section 2.2, and it is a finding rather than an obstacle: the gap is demonstrated by the implementation refusing to accept the policy, not inferred from reading a specification.

With a minimal profile extension, the chain closes. This is the part that reuses Case B, as noted above. Adding one obligation term (AnonymizeFieldClass eq "F2") took 18 added lines across four existing files and two new ones, with the profile's validation left on and an existing stock term still registering correctly; Appendix A gives the term, its schema and the registration points, so that a reader who regards the extension as the hard part can judge it directly. The term then survives an actual negotiation into the agreement object on both sides, and feeds the same compiler and gateway used in Section 8.1 with no changes. Replaying Case B's 105-case risk set with this agreement as the constraint source reproduces Case B's numbers exactly: 105 of 105 raw responses carry F2, 0 of 105 model-bound payloads do, over-removal is 0, and no model is called anywhere in the path. **Reproducing them is the point**—the substitution of a negotiated source for a fixture changed nothing downstream—and it is not a second demonstration that the gateway works.

Provider policy → catalog offer → actual negotiation → contract agreement on both sides → duty compiler → gateway → 0 of 105 protected values reaching the model.

Condition (iv) of Proposition 1 was tested on the same runtime. Twelve negotiations on the Tractus-X EDC 0.13.0 container testbed of Case A (the same runtime image as the Case E harness, not its Gradle harness) asked what a consumer obtains by naming an offer that does not exist, by widening or narrowing the permission in its request, by quoting an offer identifier that was never issued, and after the provider widens its definition post-publication. Non-existent targets were refused before any negotiation record existed (404 for a missing definition, 400 for a missing asset). The four widened requests and the one narrowed request were accepted, and in every case the agreement the provider sent carried the published policy rather than the requested one; the consumer then refused each as unequal to its own offer, so no agreement was recorded. Three negotiations finalized, and all three agreements equal the contract definition the provider stored at that moment. Two observations cut the other way and Section 5.2 states them: when the definition was widened after publication, a request quoting the old offer received the wider policy; and an identifier whose instance part was never issued was accepted once its definition and asset parts resolved. Provider-side, therefore, the bound is the stored definition and the check is substitution; the comparison that stops a mismatched agreement lives in the consumer. The proof of Proposition 1 now rests on that measured behaviour rather than on documentation.

8.4 Case D: what the approval stage is worth

Cases B and E measure enforcement. Case D measures the hazard the paper is named for. The question is not whether a classifier can be written, which is uninteresting, but what

publishing without one costs in authorization, so that the answer is a count rather than an argument.

Design. A request set of 24 policy decisions, including the two of Table 4, is frozen and hashed *before the corpus exists*. We record the freeze order because a request set chosen after seeing the drafts would return whatever reversal count its authors wanted. A corpus of 380 drafts is then generated as diffs against one published state, in ten attack classes and three non-attack classes, and hashed in turn. Each draft is applied and the request set re-evaluated. An *authorization reversal* is a request denied in the base state and permitted after the draft; the denominator is the base-denied requests only. A *duty neutralization* is a duty whose text survives unchanged but whose applicable set becomes empty. Three structures are compared: **no gate**, in which every draft publishes; **V1**, the six privilege-delta conditions as Section 5.3(b) originally stated them; and **V2**, V1 plus the classification-aware amendment of Section 5.4. No model is called anywhere in this experiment.

V1 is an ablation of our own classifier, not a baseline drawn from prior work, and the distinction changes how the numbers read. The six conditions are a syntactic reading of an ODRL diff, and Section 9.1 places them in the lineage they belong to: they are a decidable syntactic approximation of the safety question that [21] showed undecidable in general, applied to a policy diff rather than to a protection matrix. What that lineage does not supply is a system. Administrative models govern *who* may change authorization state [27]; they do not classify a proposed change as privilege-expanding, and we are aware of no published system that implements this set of conditions over agent-authored dataspace policy. So the V1 column measures what our own design caught before Section 5.4, not what the field already knew, and the comparison is informative in exactly that narrower sense.

TABLE 8. Case D. Effect of publishing 380 agent drafts on policy decisions, under three approval structures. Reversals are counted only over requests the base state denied. The V1 and V2 rows count reversals carried by drafts the classifier did *not* flag: a flagged draft is routed to elevated review, not blocked, and whether its reviewers catch it is not measured here ("What Case D is not", below).

Structure	Drafts reaching the ordinary path unflagged	Reversals among them	Duty neutralizations among them
No gate	380 / 380	80	4
V1, six conditions	240 / 380	49	0
V2, with Section 5.4	60 / 380	0	0

Two numbers carry the section, and both count what the classifier *routes*, not what it blocks: a flagged draft goes to two approvers, and Case D does not model whether they catch it. **A syntactic gate alone diverts 31 reversals** to elevated review, the difference between publishing freely and applying the six conditions. **Section 5.4 diverts the remaining 49**, and those 49 are the ones that matter,

because they are 61% of all the authorization damage in the corpus and they come from a single attack class. That share is a property of the corpus as much as of the mechanism: it is 49 because the corpus holds 50 classification drafts against 140 classic ones, and a different mix would give a different fraction. What does not depend on the mix is the mechanism—a reclassification that changes no policy text reverses decisions—and the miss rate of a policy-only classifier on it, which is 100% by construction.

TABLE 9. Case D by attack class. "Effective" counts drafts that actually changed a decision or emptied a duty; a draft with no effect is not an attack and is excluded from the false-negative denominator. Verdicts are unanimous within each class.

Class	n	Effective	V1	V2	Rev.
A1–A7 classic privilege delta	140	25	flag	flag	31
A8 classification attack	50	41	pass	flag	49
A9 vocabulary attack	50	0	pass	flag	0
A10 literal embedding	50	0	pass	reject	0
B1–B2 benign	60	—	pass	pass	0
B3 benign class tightening	30	—	pass	flag	0

The two effect metrics are disjoint, and the boundary between them is not where Section 5.4's prose suggested.

A duty neutralization is recorded only when a duty's applicable set goes from non-empty to empty, which happens when a draft removes or disables the duty rule itself; all four neutralizations come from the duty-removal class. A classification attack moves one field out of a class that contains three, so the duty still applies and the effect surfaces as an authorization reversal on requests for that field. Neither metric double-counts, but a reader following Section 5.4 would expect A8 in the neutralization column and it is not there. The corrected statement is in Section 5.4: one reclassified field narrows a duty, and only reclassifying every field of the class empties it.

The A8 row is Section 5.4 measured, and it has to be read with care about which of its numbers are measurements. Of 50 classification drafts, 41 actually moved a decision. **V1 passed 41 of 41**, a false-negative rate of 100% with a Wilson interval of 91.4–100%; V2 flagged 41 of 41 and missed none, interval 0–8.6%. **Neither figure could have come out otherwise.** V1 reads only the policy diff and an A8 draft by definition leaves the policy text unchanged, so V1 passes every A8 draft by construction; V2 flags every reclassification regardless of direction and an A8 draft by definition is a reclassification, so V2 flags every A8 draft by construction. Section 8.1 applies exactly this standard to the 105 of 105 of discovery filtering, and it applies here with the same force. What the row measures is therefore not classifier skill but what the construction does not settle: that a reclassification touching no line of policy text does reverse authorization decisions in the evaluator's semantics

—41 of 50 drafts did, producing 49 of the corpus's 80 reversals; that the effect surfaces as reversal rather than as duty neutralization (above); and what the direction-blind rule costs (below). Nor were the rules fitted to the corpus: V1 is the six conditions of Section 5.3(b), V2 adds the three unconditional classes of the same paragraph and Section 5.4, and both stood in the text of this paper and in the experiment specification before the corpus was generated, whose request set was in turn frozen before its drafts. The nine excluded drafts changed a class that no request in the frozen set depended on; they are listed by identifier in the record rather than quietly dropped. A9 and A10 pass V1 just as completely, and just as necessarily, but neither produces a reversal, because a vocabulary edit acts on later classification and a literal embedding is an exfiltration channel (T7) rather than an authorization change. Counting them as reversals would have inflated the headline, and the reversal metric is simply the wrong instrument for them.

What it costs. Under V2, 320 of 380 drafts leave the ordinary path, but they leave it in two ways and only one of them costs an approver anything. The 50 literal-embedding drafts (A10) are rejected at the submission gateway with no human in the loop (Section 5.3(b)); the other 270 are flagged for elevated review. **Escalation to human review therefore rises from 36.8% to 71.1%** of drafts, 140 to 270 of 380, and a further 13.2% is rejected automatically. An earlier draft of this paper reported the V2 figure as 84.2%, counting the rejections as escalations; the queue simulation below was run with that figure, and we say there what the correction does to it. The benign classes pay nothing: false positives are 0 of 60 on B1 and B2, interval 0–6.0%. The whole cost sits on B3, where a change that tightens a classification is flagged 30 of 30 because the amendment is deliberately direction-blind. That is not an error and we do not score it as one; it is the price of refusing to reason about whether a reclassification is benign. A reader who finds the price too high should note what the direction-sensitive alternative buys the attacker in the A8 row.

Those two percentages are properties of the corpus, not of the mechanism, and we will not report them as if they were. The caveat about prevalence at the end of this section applies to the cost side more strongly than to the benefit side. Write β for the share of drafts that are benign and γ for the share of benign drafts that change a classification. Every attack class leaves the ordinary path under V2, but the literal-embedding class is rejected rather than escalated, so 240 of the 290 attack drafts escalate under V2 against 140 under V1. The escalation rates are $(1-\beta) \cdot p_1$ and $(1-\beta) \cdot p_2 + \beta\gamma$ with $p_1 = 140/290 = 0.4828$ and $p_2 = 240/290 = 0.8276$, and the rejection rate under V2 is $(1-\beta) \cdot 50/290$. Our corpus sits at $\beta = 90/380 = 0.2368$ and $\gamma = 30/90 = 0.3333$, which yields the two headline numbers. Substituting the parameters rounded to two places does not reproduce them; the measured row is counted directly, as 140/380 and 270/380. A deployment in which nine drafts in

ten are benign and one benign draft in ten touches a classification sits at 4.8% and 17.3% instead.

TABLE 10. Escalation to human review as a function of corpus composition; the rejection column is automatic and costs no approver time. **THE FIRST ROW IS MEASURED, COUNTED DIRECTLY FROM THE 380 TRIAL RECORDS; THE OTHER THREE ARE EXTRAPOLATIONS OF THE MODEL ABOVE**, computed with $p_1 = 140/290$ and $p_2 = 240/290$ held fixed while β and γ vary. Absolute cost falls as benign drafts dominate; the ratio between the two classifiers grows.

Benign share β	Class changes among benign γ	V1, review	V2, review	V2, rejected	Ratio
0.2368 (measured)	0.3333 (measured)	36.8%	71.1%	13.2%	1.9×
0.50	0.3333	24.1%	58.0%	8.6%	2.4×
0.90	0.10	4.8%	17.3%	1.7%	3.6×
0.99	0.02	0.5%	2.8%	0.2%	5.8×

Two things follow that the single pair of numbers hides. The absolute review burden of the amendment is far smaller in any realistic mix than our corpus suggests, and the *multiple* is larger. Both matter to an operator and neither is visible in "36.8% to 71.1%". A third point is less comfortable: **the vocabulary and literal-embedding classes, 100 drafts and 26% of the corpus, contribute nothing to the 80 reversals while appearing only on the cost side**—the vocabulary class raises the escalation rate and the literal-embedding class the rejection rate. They are flagged or rejected for reasons Section 5.3 gives—a vocabulary edit acts on later classification, a literal value is exfiltration—but a reader comparing benefit against cost should know that a quarter of the corpus appears only on the cost side of this experiment.

Centralized approval is not capacity-stable at the volume the paper motivates. Section 5.3(c) bounds approver load and Section 3 describes a long tail of thousands of participants. A deterministic queue simulation over that grid finds the two incompatible *under the provisioning we evaluated*, and that qualifier is the result. The ceiling is not a threshold the mechanism imposes; it is the arithmetic of a single pool, in which service capacity $K \cdot C$ must exceed the elevated arrival rate. Our grid varies K over three, ten and thirty approvers at twenty reviews each, and takes the share of V2 drafts reaching human review from Case D as 71.1%; the 13.2% the gateway rejects never enters a queue. Under V2 at the lowest draft rate, three approvers hold to two hundred participants and have diverged at five hundred, the next point on the grid; ten hold to a thousand; thirty hold to three thousand. Raising the draft rate moves every figure down by roughly the same factor. At five thousand participants, the grid's largest point, the same arrival rate needs **sixty to a hundred and fifty approvers**, depending on how much of the volume is first publication; that range is arithmetic on the simulated arrival rate, not a simulation at those pool sizes. The Section 5.4 amendment raises the elevated arrival rate by up to a factor of 1.83 where first publications are rare (a multiple of

elevated arrivals, which onboarding volume dilutes; it is not the ratio of the two review rates, $270/140 = 1.93$), and by nothing at all where every draft is a first publication. (An earlier run took the V2 share as 84.2%, counting gateway rejections as escalations. The re-run with 71.1% changed no saturation point and no steady-state or divergence verdict; it lowered the worst-case factor from 2.17 to 1.83 and the V2 pool sizes at five thousand participants from 128–146 to 109–142. Both runs are in the evidence package.) One piece of the mechanism does work: a per-participant quota converts a flooding participant (T8) from a plane-wide stall into a local one, lifting normal drafts served from 3,340 to 7,116 while the flooder goes from 3,860 to 84. The quota changes the flooding outcome and not the saturation point, which is what a quota should do and the two are easy to conflate. **The negative result is precise.** The ceiling behaves exactly as specified. What does not scale is a single central pool of approvers, because it must be staffed in proportion to participants, and nothing in the design forces that topology. Section 10 says what the other topology is; Case D5 below simulates it, and the limit moves rather than disappears.

Case D5: the federated topology. Under the partition of Section 10, each participant reviews its own drafts and a central pool of K_c approvers reviews only the share μ of drafts that change the vocabulary, the classifier or a classification's definition. The same simulator, unmodified, is run under that partition on a pre-registration frozen before execution; its central cells reproduce the 1,008 scenarios above with no difference in any field. The local queues never build: at one review per participant per period, all 12,096 cells are steady at zero depth, which the arithmetic already implies because no participant drafts faster than that. The central queue saturates at $N^* = K_c C / (\lambda \mu)$, and the closed form matches the simulation in all 504 parameter families. **Federation moves the central limit; it does not remove it.** At the middle draft rate with three central approvers, the pool holds to the grid's largest point, five thousand participants, when $\mu \leq 0.02$; to a thousand at μ of 0.05 and 0.1; and to two hundred at μ of 0.21, no further than the centralized pool of three holds at the same draft rate (one hundred to two hundred on the grid, by gate and onboarding share). That last value is the corpus's own rate of classification changes, 80 of 380, an adversarial upper reference and not a deployment estimate; **μ is the parameter the exit depends on, and this paper has not measured it.** The ratio of the two topologies' saturation points is $[\pi + (1-\pi)e]/\mu$, not $1/\mu$. Flooding stays where the quota put it: no normal participant's local queue changed in any of the 144 flood cells, and the flooder's share that the partition routes centrally altered the central queue only in cells already diverging without it. Two things the run cannot say. Arrivals are constant per period, so every stable queue has zero waiting and there is no latency comparison to report; and a sweep of utilization from 0.90 to 1.10 in steps

of 0.02 puts every family's boundary at exactly 1.0 in both topologies, which is the closed form again rather than a finding.

What Case D is not. The policy evaluator is a reimplementaion of this paper's rules, not the EDC decision point, so the reversals are reversals in our model of the semantics and not observations of a connector. The corpus is adversarial and constructed, so it shows that the hazard is *possible and mechanical* and says nothing about how often it would arise in deployment. Case D attacks the influence channel only; it does not attempt to steal the publishing credential, so it is not evidence about the authorization channel of Section 5.2. And the approver is a classifier, not a person: fatigue and social engineering are untouched, and a flagged draft is scored as caught, which is the assumption most favourable to the approval stage; the 0 in the V2 row is a routing result, not a review result. Four further limits of the corpus bear on the cost side. The benign classes contain no *legitimate* privilege expansion—a permission an owner actually wants to add—although deployments produce these routinely; each would be flagged by V1 and V2 alike, so both absolute escalation rates are understated by the same amount and the ratio between them is not. First publication, which Section 5.3(a) sends to elevated review unconditionally and Section 3 calls the dominant event, is absent, because every draft is a diff against one published state; the queue simulation covers that path through its onboarding share, Case D does not. The A9 vocabulary class produces no reversal in a static snapshot, and an attack whose effect is deferred to later classification would need an evaluation with a time axis. And the frozen request set has 24 members, so a share such as "61% of the damage" is a share over that set, not over a population of requests.

8.5 Case A: what per-action evaluation costs

Section 6.2.4 concedes availability coupling and Section 8.1 declines to quantify it. Case A quantifies it on a testbed built from the same production connector images as Case E—the upstream Tractus-X EDC 0.13.0 end-to-end test harness, not a deployed production system—with provider, consumer, a token service and a BPN directory as separate containers. We report it as a cost the design incurs, not as a result in its favour.

TABLE 11. Case A. Cost of evaluating policy per action, against admission-time verification and against a five-second decision cache. Medians over 1,000 decision paths and 200 tool calls per variant. The admission-time column's last two rows are bounded by the observation window, not open-ended: the run ended at thirty seconds with no denial and every decision in it served. The 50-step row is the median of twenty measured 50-step plans, not fifty times the per-call median, which would read 2.4, 1,019 and 2.1 ms.

Measurement	Admission-time	Per action	Cached, 5 s
Decision path, median	—	19.25 ms	—
Decision path, p95	—	51.67 ms	—
Added per tool call	0.05 ms	20.4 ms	0.04 ms
Added over a 50-step plan	2.2 ms	1,019 ms	2.0 ms
First denial after revocation	not observed in 30 s	34 ms	5,025 ms
Decisions served after revocation	440/440 in 30 s	0	101

The decision path is not a bare policy evaluation. It is an agreement lookup, a revocation lookup and a local ODRL evaluation, and we report the composite because that is what a deployment pays. A second of added latency on a fifty-step plan is a real cost, and a reader who concludes that per-action evaluation is unaffordable for long plans is reading the table correctly.

The last two rows are the more interesting ones, because they show that the obvious remedy and the design's central property are the same knob. Caching decisions removes essentially all of the cost and returns tool-call latency to the admission-time baseline. It also serves 101 decisions on an authority that has already been revoked, and stretches the first denial from 34 ms to just over five seconds; at a thirty-second cache the figures are 593 decisions and thirty seconds. Worse, a decision path that reads only the contract agreement and does not separately query revocation **never denied at all** within a thirty-second observation window, across 440 decisions. Revocation is not visible in the agreement object. Anyone implementing Section 6.2's revocation story must query retirement explicitly, and we did not know that before measuring it.

Two further limits. Under a control-plane outage the per-action client denies and the cached client continues to permit for the remainder of its window, which is a consequence of how we built the client rather than a discovery. And one probe did not resolve: a request shaped to require the BPN directory failed with a gateway error whether that directory was up or down, so we cannot say whether catalog authorization fails open or closed in that configuration, and we decline to guess.

8.6 Secondary: prompt-only output behaviour

This is a separate study and not the 1,320 trials of Section 8.2, despite the similar total. It ran 1,350 trials across nine model and runtime configurations—900 of them adversarial, as 20 tasks by five repetitions by nine cells—and measured what models emit *after* the protected value is

already in context. It is secondary evidence and cannot serve as Case B's primary result, because in all 900 adversarial trials context exposure had already occurred by construction; a cell scoring zero demonstrates output discipline, not protection. Two observations are worth carrying.

Refusal is not non-disclosure. Of the 900 adversarial trials, 39 leaked a protected value into the final answer. **Of those 39, 24 were refusals.** The model identified the request as improper, declined it, and quoted the protected value verbatim inside the refusal. The remaining 15 were ordinary compliance with the attack. So the majority channel for disclosure in this study was not the model doing the wrong thing; it was the model doing the right thing and narrating it. A duty declared to a model is not a duty enforced, and this is one mechanism by which that stays true even when the model behaves as intended. Fifteen of the leaks were ordinary compliance; the finding is the twenty-four that were not.

Post-exposure behaviour varies materially across configurations under an identical policy and corpus—leaks concentrate in a few cells and three of the nine never leak at all—which argues for treating the model as a nuisance variable rather than fixing one, and against importing prompt-failure rates measured on earlier model generations as the expected behaviour of current ones. We therefore do not place these figures on the same axis as the unauthorized-invocation rates of [16], which measure a different event at a different boundary. Nor do we report the configurations as a ranking: their system roles, tool surfaces and turn caps are not equalized.

8.7 What these measurements do not show

Everything this section does not establish, in one place. Each item is a claim a reader could otherwise take from the numbers above.

- **The value-level duty is not a stock capability.** A minimal profile extension is required. Any statement of the provenance result must carry this qualifier.
- **Not every executable parameter comes from the agreement.** The negotiated agreement supplies the normative duty at class level—`anonymize` class F2. The mapping from that class to concrete field names is local classification metadata in this prototype, which is precisely the artifact Section 5.4 places under the publication gate. The registry-held classification of Section 5.4 is therefore designed and not implemented in this prototype; Case D's evaluator models it, and Table 13 says so. The precise form of the Section 2.3 claim is that the *normative rule* comes from the agreement, not that every parameter does.
- **The connector does not redact.** The gateway does. No claim is made that EDC or Tractus-X performs value-level enforcement.

- **"Anonymize" here means suppression.** The `AnonymizeFieldClass` duty removes the fields of a class from the model-bound payload; it does not anonymize a record in the statistical sense, and the stress group's derivable-value cases are exactly where the difference shows. The name follows the profile's stock `Anonymize` action, to which the term attaches.
- **One shortcut remains in the identity path.** Public-key resolution is served from a fixed test key pool. Documents are still served over HTTP and signatures are still verified, and expired, revoked, wrong-subject and missing-credential controls do fail the catalog request; only key distribution is short-circuited.
- **Scope is one tool and a small action set.** Nothing here shows that arbitrary ODRL duties compile or that the result generalizes across tool ecosystems.
- **There is no external baseline, so every comparison condition is ours.** No standard benchmark exists for governed agentic data access. DAVE [1] routes question-answering through a provider-side spokesperson service, but its authors state that they do not yet implement or empirically evaluate the full enforcement pipeline, so it cannot serve as an empirical baseline; comparing on document-QA leakage would also place us in a lane we argue is the wrong one. Prompt-only and discovery filtering are therefore our implementations of those mechanisms rather than the cited systems, and Case D's no-gate condition is a third constructed control. Releasing the corpus, scorer and raw trials improves reproducibility; it does not improve external validity. The nearest thing to an external baseline is change-impact analysis [28] over the frozen Case D corpus, which Section 9.1 argues an A8 draft defeats by construction; running it would turn that argument into a measurement. It is unrun: it needs Margrave and an XACML decision point against which the translation of our ODRL dialect could be validated, and we have neither. The other candidate, EDC's own decision point in place of `pdp.py`, is not executable on stock Tractus-X EDC 0.13.0: the policy validator refuses the Case D vocabulary (ten registrations, all rejected), and the connector's policy contexts carry the participant, the agreement and the time but no field, purpose or delegation depth, which is what all 80 reversals turn on. Supplying those would re-implement `pdp.py` inside EDC rather than test it against EDC. That is the caveat above in its sharpest form: the connector does not evaluate what Case D measures. It also bounds Section 7: per-action evaluation over fields, purpose and delegation depth requires registering constraint functions in that decision point, the same kind of extension as Appendix A. The decision authority stays single; the engine is not used as is. This is a prototype on an upstream test harness, not a validated production deployment.

- **Case C was not run, and it is the experiment that would test Section 6.2.** Its two halves are *C-utility*, how often the default ceiling blocks a decomposition a domain expert judges legitimate, and *C-composition*, whether an adversarial planner can find a sequence of individually permitted actions whose combined output violates a prohibition (T5). We expect the second to succeed in some cases; characterizing which is the value of the experiment. We also did not attempt the second half of Case A as originally scoped: whether a terminated agreement denies at the next action is true by construction, and an experiment that cannot fail is not one, so we measured latency and revocation timing instead, which did surprise us (Section 8.5).

9. Related Work

9.1 Classical authorization and policy administration

The first question a reader from the access-control tradition should ask is whether the authorship hazard is administrative access control under another name. It is worth answering directly rather than avoiding the lineage.

That lineage is the right one to start from. The safety question—can a given subject ever acquire a given right—was posed and shown undecidable in the general protection model [21], and the models that followed bought decidability with structure: roles mediating between subjects and permissions [29], and administrative scopes governing who may change role and permission assignment [27]. Our approval stage is likewise an instance of separation of duty [30]: the party that drafts a change is not the party that commits it. None of that is new and we do not present it as such.

The divergence is in where the untrusted party sits. Administrative models answer who holds the authority to change authorization state, and their protection is that an agent lacking administrative roles cannot change it. Our agent lacks exactly that authority—Section 5.2 closes the authorization channel by construction, which is the administrative answer implemented—and the hazard survives anyway, because the agent can still write the artifact that a party holding the authority will adopt. ARBAC97 has no vocabulary for a subject with no administrative permissions whose output nonetheless reaches the administrative decision as its content. That is the influence channel of Section 5.3, and it is a property of an administrator whose review capacity is finite rather than a property of the permission lattice. Table 1 marks the approver *trusted but bounded* for this reason; classical administrative models have no such row because they have no drafting agent.

The second divergence is what counts as authorization state. Administrative scoping governs role and permission assignment. It does not govern the vocabulary a policy's conditions dereference. Section 5.4

shows that moving a field between sensitivity classes changes what the policy protects while the policy text, and every permission assignment in it, stays fixed—a change the administrative models treat as data, not privilege. Mandatory models do know it. Bell–LaPadula's tranquility assumption forbids changing an object's label while it is in use [31]; the declassification literature treats the downgrade as the security-relevant act and asks who may perform it, where and when [32]; and attribute-administration models for ABAC place attribute assignment itself under administrative control [33]. Moving consignee from F2 to F0 is a declassification in exactly that sense, and Section 5.4 rests on an old MLS principle that the dataspace agent setting has dropped: the administrative models in use there treat labels as data, and the party proposing a relabelling is the agent the label constrains. The vocabulary a policy dereferences is authorization state and must be administered as such. What Case D adds is the measurement—49 of 80 authorization reversals when it is not. The point is sharper against the tools built on these models than against the models themselves. Change-impact analysis [28] and security analysis for administrative RBAC [34] both take the policy as their subject: the first diffs two policy versions, the second explores states reachable by administrative operations. An A8 draft submits an identical policy and a different classification, so the first sees no diff and the second no operation. The vocabulary is not in either tool's input. Separation of duty applied to the policy and not to its vocabulary leaves that door open. The contribution here is not a new administrative model; it is the observation that the administrative boundary has to be drawn around the classification as well, and the measurement of what it costs when it is not.

Usage control [8] is the other inheritance and we are explicit about it in Section 1.3. Obligations, conditions, continuity and mutability are all pre-existing; an ODRL duty enforced after access is a usage-control duty, and Section 9.4 places our executor inside that tradition rather than beside it. What we add at execution time is provenance and placement, not the concept.

Finally, the design's limits are limits the same literature already named. Complete mediation and least privilege [24] are what Section 6.1 applies and what discovery-time filtering fails. And the boundary this design cannot cross is the one between access control and information flow [19]: a parent relaying a value it lawfully holds is a flow, not an access, so no non-interference property follows from anything we build (T6, Section 10).

9.2 LLMs inside the enforcement path

DAVE [1] is the closest system and it is easy to mischaracterize. Its post-generation layer is largely deterministic—pattern and entity-based detectors, and verbatim/near-verbatim leakage control by similarity between answer segments and retrieved chunks—with an

LLM supervisor that is explicitly optional. The constraint instructions given to the generating model are described as advisory. The probabilistic component is thus not the redactor but two dependencies upstream and downstream of it. Upstream, policy-aware retrieval excludes chunks whose sensitivity tags conflict with prohibitions, and those tags are NER-derived, so enforcement accuracy is bounded by entity-recognizer recall. Downstream, compliance is defined so that an answer is compliant if for every information item i all chunks in $src(i)$ are disclosable—a definition that requires span-level provenance of what the generator grounded each item on, and no mechanism is given for obtaining it. That second dependency is the sharper point of divergence: our executor acts on fields whose sensitivity class was assigned under human approval and held in the registry (Sections 5.3–5.4), so the question "which chunks did the model rely on" never arises. We should be precise about what the difference is. It is not that our classification is deterministic and DAVE's is not; ours is drafted by an agent too. It is that ours passes a publication gate before any policy may refer to it—Section 1.1 applied to vocabulary. A 2026 literature has grown around improving DAVE's lane—policy-aware vector search, privacy-preserving retrieval, redaction benchmarks, and risk-budget accounting across turns [35]. We reject the premise of an inferential component in the enforcement path rather than compete on its failure rate; this is a design disagreement, not a claim of superiority.

It is worth separating two families that are often grouped. In *model-mediated* enforcement a model or a separate guard agent participates in the decision: GuardAgent [14] reasons about whether another agent satisfies guard conditions, and DAVE's optional supervisor sits in the same family. In *deterministic architectural* enforcement the decision and the enforcement both live outside the model, in a reference monitor, proxy or policy engine—AgentSpec [13], Progent [12], the MCP proxy of [16], and our Case B. The axes that separate them are who decides, who enforces, what is trusted, where the normative constraint originates, and whether protected data reaches the model before enforcement acts. On the last axis Section 8.1 is a measurement rather than an argument. AgentSpec is the closest comparison on the enforcement axis and differs on the origin axis: its rules are authored for the runtime, whereas ours are derived from a negotiated agreement between two organizations and must not be wider than it. Our runtime enforcement is not novel by itself, and Section 1.3 says so.

9.3 Credentialing and capability

The IDSA position paper [2] is the standards-track statement of the problem and, as Section 5.1 concedes, anticipates both of our cases conceptually. Agent authority via verifiable credentials is otherwise crowded but consistently in OAuth, OIDC, DID and zero-knowledge settings rather than ODRL or dataspace; the Gaia-X ODRL

credential profile covers organizations only. Agent infrastructure such as [26] propagates constraints across MCP and A2A chains using capability-based control inspired by Macaroons [25] and UCAN, and explicitly excludes post-access duties, usage control and runtime enforcement. Progent [12] enforces developer-authored privilege policies with a shrink-only guarantee; our compiler must preserve the same monotonicity with the agreement as source.

9.4 Policy generation and enforcement

AgentODRL [3] and ontology-guided instruction-to-ODRL translation [4] generate policies; neither governs their publication. ODRE [36] supplies an enforcement algorithm and implementations for ODRL and is the lineage we work in. Relationship-based authorization over an ODRL dataspace profile [37] compiles policy into a deterministic engine, the same instinct applied to organizations rather than agents. Deterministic duty enforcement is mature in the IDS lineage—MYDATA and LUCON [38], IDS-RAM usage control [39], and external enforcement components deployed as separate services—which in turn implements the usage-control model of [8]. Our executor is an implementation detail within that tradition, not a contribution. The duty it enforces is a UCON obligation; what is ours is that the obligation is carried from a negotiated agreement (Section 8.3) to the model's tool boundary (Section 6.1) without either end being restated by hand.

9.5 Agentic construction of governance artifacts: a survey

This subsection is the evidence behind Section 1.1, and it is the only evidence the framing contribution currently has. It belongs in Related Work because it is a reading of other systems, but it is doing the work of a result, and Section 10 counts it as one.

Method. We selected systems that use LLM agents to produce artifacts a dataspace would govern—ODRL policies, ontologies, schema alignments—from the venues and surveys cited in Section 1.1. For each we read the evaluation section and asked one question: is there any step, human or automated, at which the generated artifact is authorized for use in a governed or production setting, as distinct from being scored for quality? Inspection depth varied and is recorded.

TABLE 12. Survey of agentic generation systems for a publication or authorization step.

System	Artifact	Quality evaluation	Depth	Auth. step
AgentODRL [3]	ODRL policy	770 use cases; syntactic validity; SHACL loop	Full text	None
Mustafa et al. [4]	ODRL policy	Accuracy vs ontology-guided gold (91.95%)	Full text	None
Agent-OM [5]	Ontology alignment	OAEI tracks; precision/recall	Abstract + eval.	None
Talukder et al. [6]	Ontology	LLM-judge panel; competency-question SPARQL	Abstract + eval.	None

The survey is four systems and we do not present it as exhaustive; two further systems from the same workshop venue were examined at abstract level only and are omitted rather than reported at that depth. Its point is narrower, and it is not a criticism of those systems: across the systems a dataspace practitioner would actually reach for, publication is not modeled, because a generator is evaluated on what it generates and the authorization of its output belongs to a different literature—one that does not model the generator. The seam between the two is empty, and that is where the authorship hazard has gone unnamed. It is also why we decline to claim the mapping capability itself: against [5] on alignment quality we would lose, and correctly.

We also report a negative result: the agent-driven semantic mapping capability that motivated this work is not defensible as a contribution against [5], and we do not claim it.

10. Limitations

The evidence is now uneven in a different way than before. The table below sets each claim against its evidence. Two rows were filled by the experiments of Sections 8.4 and 8.5; one row remains empty and one is filled at a single point; and two of the rows we did fill hold results that go against us.

TABLE 13. Claim against evidence. The first row is the paper's title.

Claim	Threats	Evidence
Authorship hazard; publication is a governance event (1.1)	—	Survey (9.5), argument, and Case D: 80 reversals ungated (8.4)
Classification is policy-rank authorship (5.4)	T2	Case D: 49 of 80 reversals from drafts that change no policy text; the syntactic classifier passes all 41 effective drafts and the amendment flags all 41, both by construction (8.4). Ablation of our own design, not a prior-work baseline; measures routing, not review. Registry-held classification (5.4) designed, not implemented in the prototype—Case D's evaluator models it
C1: agent as subject, authorization channel closed (5.1–5.2)	T1	Construction argument for (i)–(iii). Condition (iv) measured: 12 negotiations on Tractus-X EDC 0.13.0, every finalized agreement equal to the provider's stored policy; the bound is the stored definition, not the offer seen (8.3). No experiment attacks (i)–(iii)
Approval load is bounded per approver and floods are localized; central capacity scales with participants (5.3c)	T8	Case D: quota localizes flooding; central capacity is a provisioning parameter — 3 approvers hold to 200 participants and have diverged by 500 at the lowest draft rate, 30 hold to 3,000. Case D5: a federated partition keeps every local queue empty and moves the central limit to $K_c C/(\lambda \mu)$; μ unmeasured (8.4)
C2 downward: duties act on values at invocation (6.1)	T3	Case B, 105 cases and 1,320 calls (8.1, 8.2)
... for protected values not in named fields	T3	Contradicted. 7 of 7 exposed on the stress group (8.1)
The constraint derives from the negotiated agreement (2.3)	—	Case E (8.3)
Per-action evaluation is affordable	—	Not claimed. Case A measures the cost (8.5)
Owner-declared ceiling on re-delegation (6.2)	T4	Design only; not claimed as a contribution

Three things follow. The first is that the classification row carries the sharpest number in the paper, and it is the row that neither Section 9.1 nor Section 9.4 can call derivative. The second is that one row is still empty and one is filled at a single point, and they are not the same kind of gap. The closure of the authorization channel is a construction claim; Section 8.3 measured its condition (iv) on the connector and found it holds by substitution, no experiment attacked conditions (i) to (iii), and Case D attacked the influence channel only. The owner-declared ceiling is unevaluated because Case C was not run, and Section 6.2 already declines to claim it.

The third is the uncomfortable one. Two of the rows we did fill came out against the design. Value-level enforcement does not survive contact with protected values that are not in named fields, and a centrally provisioned

approver pool is not capacity-stable at the participant volume of Section 3; the federated partition of Case D5 moves that limit onto an unmeasured share rather than removing it. They mark where the next version of this work has to go.

The limitations below are stated in order of how much they should worry a reader.

Composition (T5) is unaddressed. A planner can decompose a forbidden goal into individually permitted actions across itself and its sub-agents, and a stateless per-action evaluator will admit every one. Our advertised properties—no token, no persistent state—are exactly what make the design blind here, and a system that keeps session context, as DAVE does, has at least the raw material to notice. The mitigation we consider is session-scoped accounting within the agreement: a per-session budget over sensitive-field exposure, in the spirit of the risk-feedback budget of [35], evaluated by the PDP as one more constraint. This is compatible with per-action evaluation—the budget is state the agreement owns, not state the agent holds—but we have not designed it and Case C-composition exists to measure how much it is needed.

The ceiling is an access boundary, not a confinement boundary (T6). A parent that lawfully holds a field can relay it to a child in a prompt, and no evaluation at the PDP sees that flow. This is the distinction between access control and information-flow control [19], and the design lives entirely in the former; it establishes no non-interference property, as [1] also declines to claim for its own design. Reaching T6 would require either a trusted boundary around the parent that mediates what it may emit to children—a gateway on the A2A channel applying the child's ceiling to the parent's outbound messages, a plausible extension of Section 6.1—or labelled data with taint propagation through the planner, which is not.

The influence channel is bounded, not closed. Section 5.3 makes adversarial drafting costly and visible; it does not make it impossible. Approver fatigue and social engineering of approvers remain, and the classification fix of Section 5.4 moves reclassification onto the elevated path without removing the approver from it. The reviewer's hit rate on a reclassification that reads as a label correction is the unmeasured quantity on which the zero in Table 8's last row depends.

Revocation is coarse and availability is coupled (Section 6.2.4). For deployments that need branch-level revocation or offline operation, a capability design is better.

For the capacity failure we can at least say what the shape of the answer is. The simulation assumes a single central pool of approvers, and that assumption is not forced by anything in the design. Section 7 places the registration agent inside the participant boundary and Section 3 requires the profile never to leave it, which makes the participant the

party best placed to review its own asset's mapping and policy—and the party a dataspace's sovereignty model already treats as responsible for them. Under a *federated* approval structure, local approvers scale with participants by construction, and only three things need central review: changes to the vocabulary registry, changes to the classifier, and changes to a classification's definition. Section 5.3(b) already separates exactly those three as the highest-privilege changes. Case D5 runs the same simulator under that partition (Section 8.4): local queues never build, and the central pool's limit becomes $K_c C / (\lambda \mu)$, finite for every $\mu > 0$ and inverse in the share μ of drafts that need central review. The exit therefore exists, and its width is a number this paper does not have: whether central-rank changes are rare is a deployment measurement, and at the corpus's own rate of classification changes a federated pool of three holds no further than the centralized one. We report the topology as the shape of the answer and μ as its open parameter.

Case E rests on a profile extension we wrote. The chain from negotiated agreement to enforced constraint closes, but only after adding a term the stock profile refuses (Section 8.3). A reader who regards that extension as the hard part is entitled to; our claim is that it is 18 lines and that the rest of the path is unmodified, not that the term is already available.

Conceptual priority on agent authority is [2]'s. Our framing contribution is the authorship hazard; our mechanistic contribution is an alternative design. The paper must not be read as claiming more.

The profile term is not standardized. Section 8.3 shows it can be added to the profile in 18 lines with validation left on, on the upstream Tractus-X EDC 0.13.0 end-to-end test harness, which is an argument for feasibility and not for adoption. The base profile is itself an unofficial draft (Section 2.2), which cuts both ways: it lowers the barrier to proposing the term, and it lowers what the term's presence would guarantee if it were accepted.

The window may close. IDSA has a task force active and has signalled Rulebook treatment. Should a specification land first, this work becomes a comparison against a standard. Engagement with that process may be a better strategy than competition; we note it as strategy, not as a technical limitation.

11. Conclusion

The temptation when agents enter a governed environment is to add something: a model in the enforcement path, or a verification stack beside the policy plane. We have argued that the first productive move is to look at a different literature—the one that has agents *write* governance artifacts—and notice that it never models publication. Once publication is seen as the governance event, the hazard of an agent authoring its own norms is visible—and so is the quieter hazard of an agent authoring the classification those

norms refer to—and a principle against both follows. Closing the authorization channel is structural and cheap; bounding the influence channel is enforcement and ongoing. Leaving authority in the agreement means no rights-bearing artifact is minted, at the price of coarse revocation and coupling to the decision point. Adding the duty executor and the compiler that the connector never had leaves the connector unforked and the decision authority single. The downward mechanism is measured: on this corpus the agreement's duty reaches the tool boundary and the protected value does not reach the model in any case in which it otherwise would, and the constraint is traced back to a contract two parties actually negotiated on the upstream Tractus-X EDC 0.13.0 end-to-end test harness, which required teaching that connector's policy profile a term it refuses.

The hazard itself is measured too. Publishing agent drafts with no approval stage reverses eighty authorization decisions in a corpus of three hundred and eighty; a syntactic classifier over the policy diff flags thirty-one of them for elevated review; and the forty-nine it lets through unflagged all come from drafts that change a classification while leaving every line of policy text alone. **In this corpus the quieter hazard is the larger one.** Treating classification as authorship routes every such draft to elevated review—completely, and by construction, since the amendment flags every reclassification—at the cost of an escalation rate that nearly doubles, from 36.8% to 71.1% of drafts. Whether the reviewers who receive them catch them is the human-factors question this paper bounds and does not measure.

Two measurements went against us and we have left them in the foreground. Value-level enforcement holds for protected values that sit in named fields and fails, seven cases out of seven, for values embedded in free text or derivable from permitted ones. The approver ceiling behaves exactly as specified; what does not scale is a single central pool of reviewers, which must be staffed in proportion to the participant volume this paper used to motivate the problem. A federated partition moves that limit onto the share of changes that need central review, a share we did not measure. What remains is one principle—subjects, not authors—a hazard now named, surveyed and measured, a mechanism carried from an agreement to where the agent acts and shown to hold on the easy half of its problem, an authorization channel closed by construction and measured at one of its four conditions, a second mechanism designed and not claimed, and two threats named and not met.

Author Contributions

S.L. conceived the authorship-hazard framing and Principle P, designed C1 and C2 including the approval stage, the owner-declared ceiling and the attestation chain, and wrote the paper. C.L. designed and executed every experiment in

Section 8: the three-condition harness and corpora of Cases B and E, the duty compiler and gateway prototype, the end-to-end negotiation experiment on the Tractus-X test harness, the minimal policy-profile extension of Appendix A, the frozen request set, draft corpus and classifiers of Case D with its queue simulation and the federated variant of Case D5, and the connector testbed and measurement harness of Case A. C.L. also built the stress group of Section 8.1 and the queue simulation whose capacity ceiling is reported in Section 8.4, the two experiments that produce results against the design; the no-gate condition of Section 8.4 is a constructed control, not an adverse result. Both authors agreed the scope and wording of the claims and limitations.

Appendix A. The profile extension

The obligation term added to the Catena-X policy profile in Section 8.3, given so the 18-line claim can be checked. The term's meaning, carried in the schema as an annotation, is: *before data covered by this agreement is released into an agent execution context, fields classified with the sensitivity class specified herein shall be suppressed.*

Term and constraint shape. A single atomic constraint, restricted to equality against a sensitivity class label:

```
cx-policy:AnonymizeFieldClass eq "F2"
leftOperand fixed to AnonymizeFieldClass, operator fixed
to eq, rightOperand matching ^F[0-9]$, no additional
properties.
```

Where the 18 lines go. Four existing files and two new ones, with the profile's validator left enabled throughout.

File	Change
Policy validation constants	One literal added; one entry appended to the allowed obligation left-operand list
Atomic constraint schema index	One \$ref to the new schema
Policy extension	Constraint function registered for the duty rule type in the transfer-process and policy-monitor contexts
JSON-LD context document	One term definition binding the label to its profile IRI
New: constraint function	Evaluates the duty constraint
New: constraint schema	The shape above, with the obligation text as an annotation

Two properties of this patch matter for the claim. Validation is not disabled anywhere; the term is added to the allowed vocabulary rather than the check being bypassed. And an existing stock term continues to register and negotiate correctly afterwards, which is the regression control for the change.

References

1. R. Brinkhege and P. Menon. DAVE: A Policy-Enforcing LLM Spokesperson for Secure Multi-Document Data Sharing. arXiv:2602.17413, Feb. 2026.

2. International Data Spaces Association. Data Spaces and AI: Trustworthy Agentic Participation in Data Spaces. Position paper, version 1.0, 9 July 2026. DOI 10.5281/zenodo.21279055.
3. W. Zhong, Huang and Du. AgentODRL: A Large Language Model-based Multi-agent System for ODRL Generation. arXiv:2512.00602, Nov. 2025.
4. Mustafa et al. From Instructions to ODRL Usage Policies: An Ontology Guided Approach. VLDB LLM+KG Workshop, 2024. arXiv:2506.03301.
5. Z. Qiang, W. Wang and K. Taylor. Agent-OM: Leveraging LLM Agents for Ontology Matching. *Proceedings of the VLDB Endowment*, 18(3):516–529, 2024. DOI 10.14778/3712221.3712222.
6. A. Talukder, M. A. Mridul and O. Seneviratne. Towards Automated Ontology Generation from Unstructured Text: A Multi-Agent LLM Approach. arXiv:2604.23090, Apr. 2026.
7. H. Bian. LLM-Empowered Knowledge Graph Construction: A Survey. arXiv:2510.20345, Oct. 2025.
8. J. Park and R. Sandhu. The UCON_{ABC} Usage Control Model. *ACM Transactions on Information and System Security*, 7(1):128–174, 2004. DOI 10.1145/984334.984339.
9. Salvachúa, Muñoz, Huecas, Aparicio and Menendez (UPM/IPTC). ODRL Profile: Data Spaces. Unofficial draft in the W3C ODRL Community Group repository, undated. <https://w3c.github.io/odrl/profile-dataspaces/>, retrieved 22 Sep. 2026.
10. Q. Zhan, Z. Liang, Z. Ying and D. Kang. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pp. 10471–10506, 2024. DOI 10.18653/v1/2024.findings-acl.624.
11. E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke and A. Beutel. The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions. arXiv:2404.13208, 2024.
12. T. Shi, J. He, Z. Wang, H. Li, L. Wu, W. Guo and D. Song. Progent: Securing AI Agents with Privilege Control. arXiv:2504.11703, 2025.
13. H. Wang, C. M. Poskitt and J. Sun. AgentSpec: Customizable Runtime Enforcement for Safe and Reliable LLM Agents. In *Proc. 48th IEEE/ACM International Conference on Software Engineering (ICSE)*, 2026.
14. Z. Xiang et al. GuardAgent: Safeguard LLM Agents by a Guard Agent via Knowledge-Enabled Reasoning. In *Proc. 42nd International Conference on Machine Learning (ICML)*, 2025.
15. J. Lichtefeld, J. A. Cecil, A. Hedges, J. Abramson and M. Freedman. Redacted Contextual Question Answering with Generative Large Language Models. In *Proc. First Int. Conf. on NLP and AI for Cyber Security (NLPAICS)*, pp. 230–237, Lancaster, UK, 2024.
16. R. Uppala. Prompts Don't Protect: Architectural Enforcement via MCP Proxy for LLM Tool Access Control. arXiv:2605.18414, May 2026.
17. M. Franklin, A. Halevy and D. Maier. From Databases to Dataspaces: A New Abstraction for Information Management. *SIGMOD Record*, 34(4), 2005.
18. R. G. Smith. The Contract Net Protocol: High-Level Communication and Control in a Distributed Problem Solver. *IEEE Transactions on Computers*, C-29(12), 1980.
19. D. E. Denning. A Lattice Model of Secure Information Flow. *Communications of the ACM*, 19(5):236–243, 1976. DOI 10.1145/360051.360056.
20. A. J. I. Jones and M. Sergot. On the Characterisation of Law and Computer Systems: The Normative Systems Perspective. In *Deontic Logic in Computer Science*, 1993.
21. M. A. Harrison, W. L. Ruzzo and J. D. Ullman. Protection in Operating Systems. *Communications of the ACM*, 19(8):461–471, 1976.
22. N. Hardy. The Confused Deputy (or Why Capabilities Might Have Been Invented). *ACM SIGOPS Operating Systems Review*, 22(4):36–38, 1988. DOI 10.1145/54289.871709.
23. P. Ladisa, H. Plate, M. Martinez and O. Barais. SoK: Taxonomy of Attacks on Open-Source Software Supply Chains. In *Proc. IEEE Symposium on Security and Privacy (SP)*, pp. 1509–1526, 2023.
24. J. H. Saltzer and M. D. Schroeder. The Protection of Information in Computer Systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975. DOI 10.1109/PROC.1975.9939.
25. A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrabie and M. Lentzner. Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud. *NDSS*, 2014.
26. S. Prakash. AIP: Agent Identity Protocol for Verifiable Delegation Across MCP and A2A. arXiv:2603.24775, Mar. 2026.
27. R. Sandhu, V. Bhamidipati and Q. Munawer. The ARBAC97 Model for Role-Based Administration of Roles. *ACM Transactions on Information and System Security*, 2(1):105–135, 1999. DOI 10.1145/300830.300839.
28. K. Fisler, S. Krishnamurthi, L. A. Meyerovich and M. C. Tschantz. Verification and Change-Impact Analysis of Access-Control Policies. In *Proc. 27th International Conference on Software Engineering (ICSE)*, pp. 196–205, 2005. DOI 10.1145/1062455.1062502.
29. R. S. Sandhu, E. J. Coyne, H. L. Feinstein and C. E. Youman. Role-Based Access Control Models. *IEEE Computer*, 29(2):38–47, 1996. DOI 10.1109/2.485845.
30. D. D. Clark and D. R. Wilson. A Comparison of Commercial and Military Computer Security Policies. In *Proc. IEEE Symposium on Security and Privacy*, pp. 184–194, 1987.
31. D. E. Bell and L. J. LaPadula. Secure Computer System: Unified Exposition and Multics Interpretation. Technical Report MTR-2997 Rev. 1, The MITRE Corporation, Bedford, MA, Mar. 1976.
32. A. Sabelfeld and D. Sands. Declassification: Dimensions and Principles. *Journal of Computer Security*, 17(5):517–548, 2009. DOI 10.3233/JCS-2009-0352.
33. X. Jin, R. Krishnan and R. Sandhu. A Role-Based Administration Model for Attributes. In *Proc. First International Workshop on Secure and Resilient Architectures and Systems (SRAS)*, 2012. DOI 10.1145/2420936.2420938.
34. N. Li and M. V. Tripunitara. Security Analysis in Role-Based Access Control. *ACM Transactions on Information and System Security*, 9(4):391–420, 2006. DOI 10.1145/1187441.1187442.
35. Q. Yang, Y. Li and X. Ma. Private-RAG: A Privacy-Preserving Retrieval-Augmented Generation Method for Large Model Inference. *Electronics*, 15(12):2567, June 2026. DOI 10.3390/electronics15122567.
36. A. Cimmino, J. Cano-Benito and R. García-Castro. Open Digital Rights Enforcement Framework (ODRE): From Descriptive to Enforceable Policies. *Computers & Security*, 150:104282, 2025. DOI 10.1016/j.cose.2024.104282.
37. I. Plaza-Ortiz et al. Authentication and Authorization in Data Spaces: A Relationship-Based Access Control Approach Based on ODRL. *OPAL* 2025. arXiv:2505.24742.
38. International Data Spaces Association. Data Usage Control Technologies (MYDATA, LUCON).
39. International Data Spaces Association. IDS Reference Architecture Model 4 (IDS-RAM 4), §4.1.6 Usage Control. 2022. <https://docs.internationaldataspaces.org/ids-knowledgebase/ids-ram-4/>

Prior-art claims were checked against primary sources on 18 September 2026. All figures in Section 8 were recomputed from the raw trial records rather than transcribed from run summaries.